

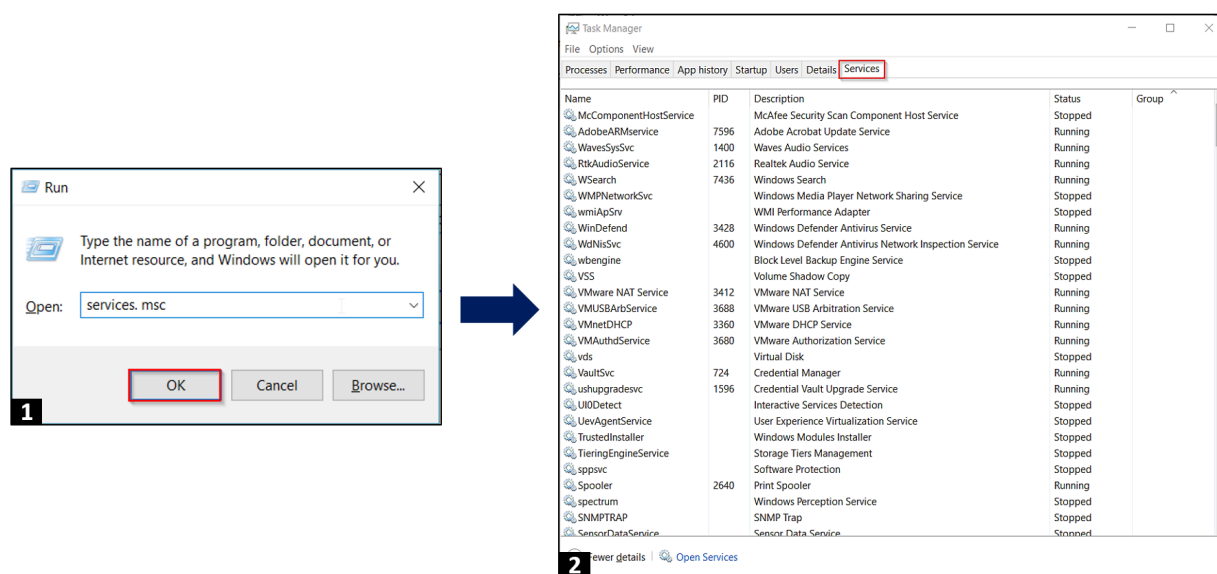
Eng 3.3. Microsoft Windows Hardening

Task 1 - Introduction

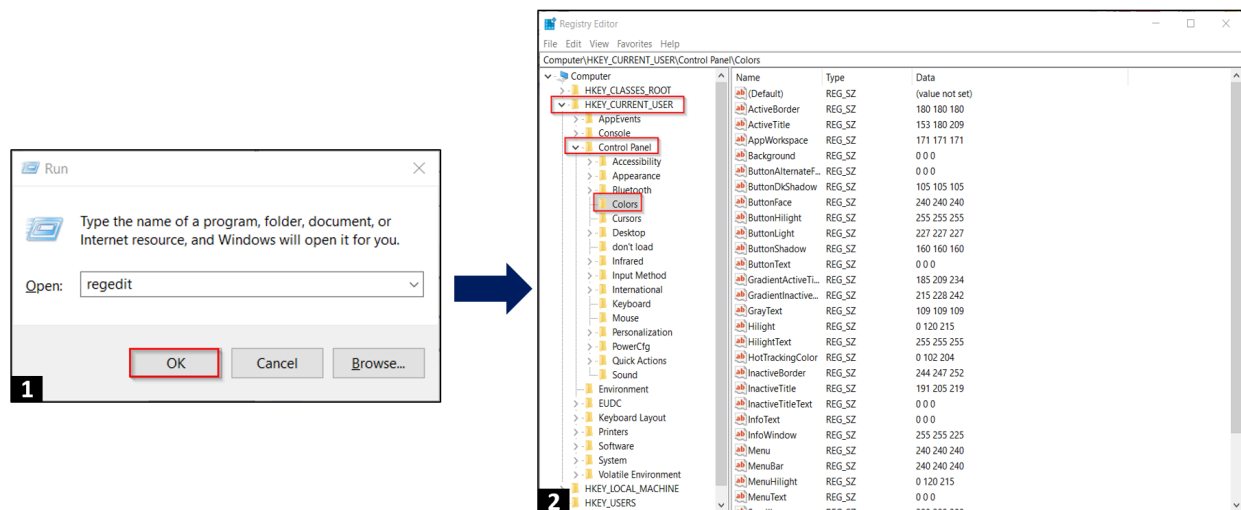
The room aims to teach basic concepts required to harden a workstation coupled with knowledge of services/software/applications that may result in hacking a computer or data breach.

Task 2 - Understanding General Concepts

Services: Windows Services create and manage critical functions such as network connectivity, storage, memory, sound, user credentials, and data backup and runs automatically in the background. These services are managed by the Service Control Manager panel and divided into three categories, i.e. Local, Network & System. Many applications like browsers and anti-virus software can also run their services for a seamless user experience. Type `services.msc` in the Run window to access Windows services.



Windows Registry: The Windows registry is a unified container database that stores configurational settings, essential keys and shared preferences for Windows and third-party applications. Usually, on the installation of most applications, it uses a registry editor for storing various states of the application. For example, suppose an application (malicious or normal) wants to execute itself during the computer boot-up process; In that case, it will store its entry in the Run & Run Once key. Usually, a malicious program makes undesired changes in the registry editor and tries to abuse its program or service as part of system routine activities. It is always recommended to protect the registry editor by limiting its access to unauthorised users. Type `regedit` in the Run dialogue or taskbar search to access the registry editor.

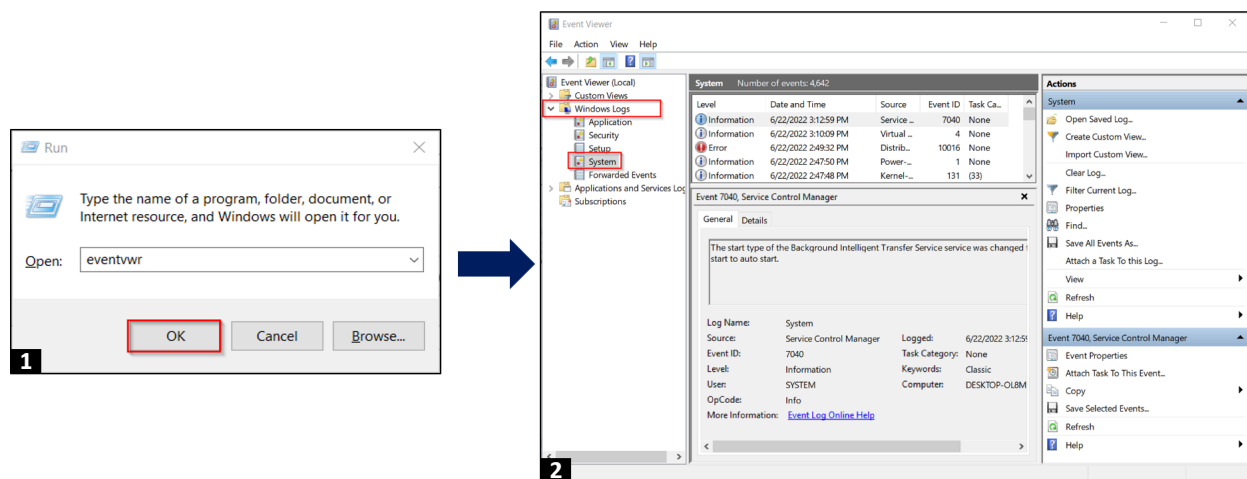


Event Viewer: Event Viewer is an app that shows log details about all events occurring on your computer, including driver updates, hardware failures, changes in the operating system, invalid authentication attempts and application crash logs. Event Viewer receives notifications from different services and applications running on the computer and stores them in a centralised database. Hackers and malicious actors access Event Viewer to increase their attack surface and enhance the target system's profiling. Event categories are as below:

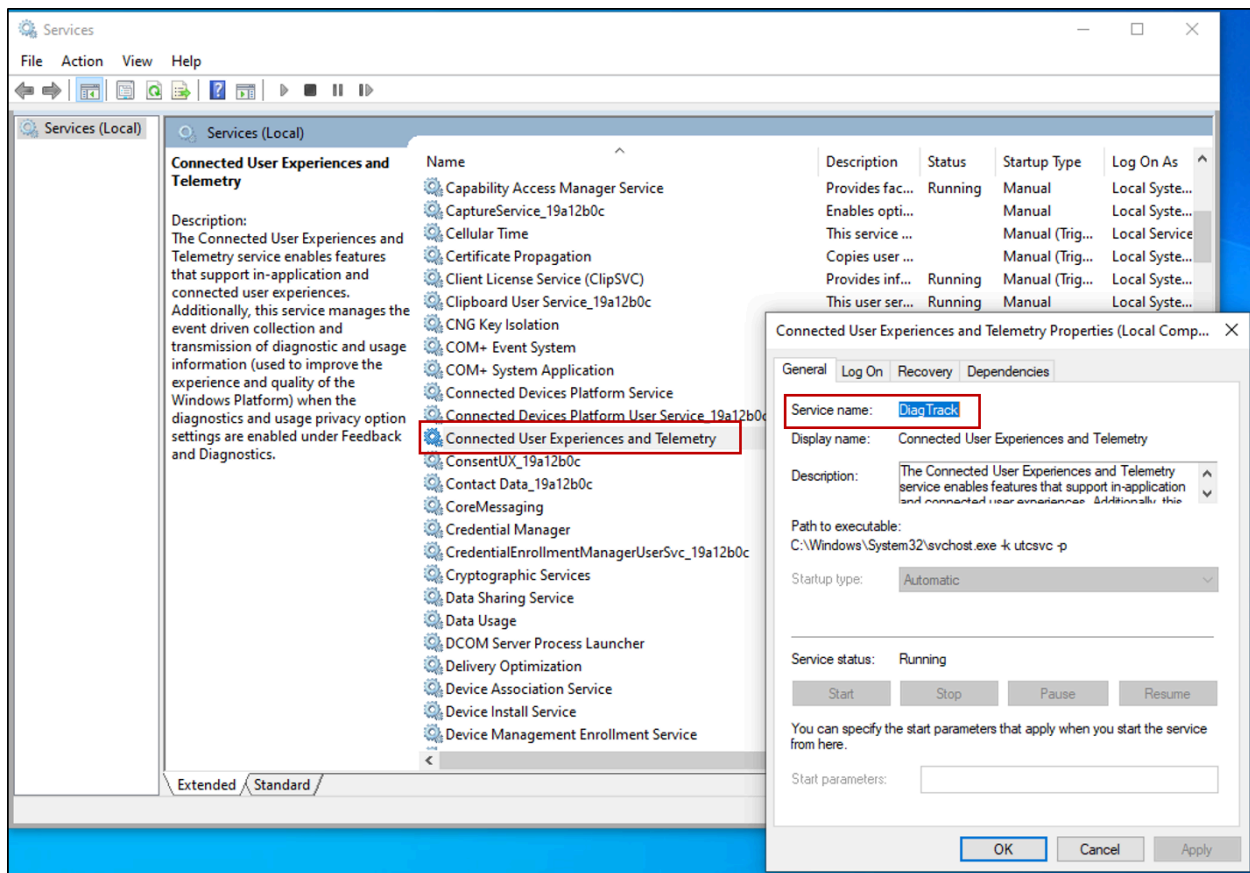
- Application: Records events of already installed programs.
- System: Records events of system components.

- Security: Logs events related to security and authentication etc.

We can access Event Viewer by typing `eventvwr` in the Run window. The default location for storing events is `C:\WINDOWS\system32\config\folder` in the attached VM (`MACHINE_IP`).

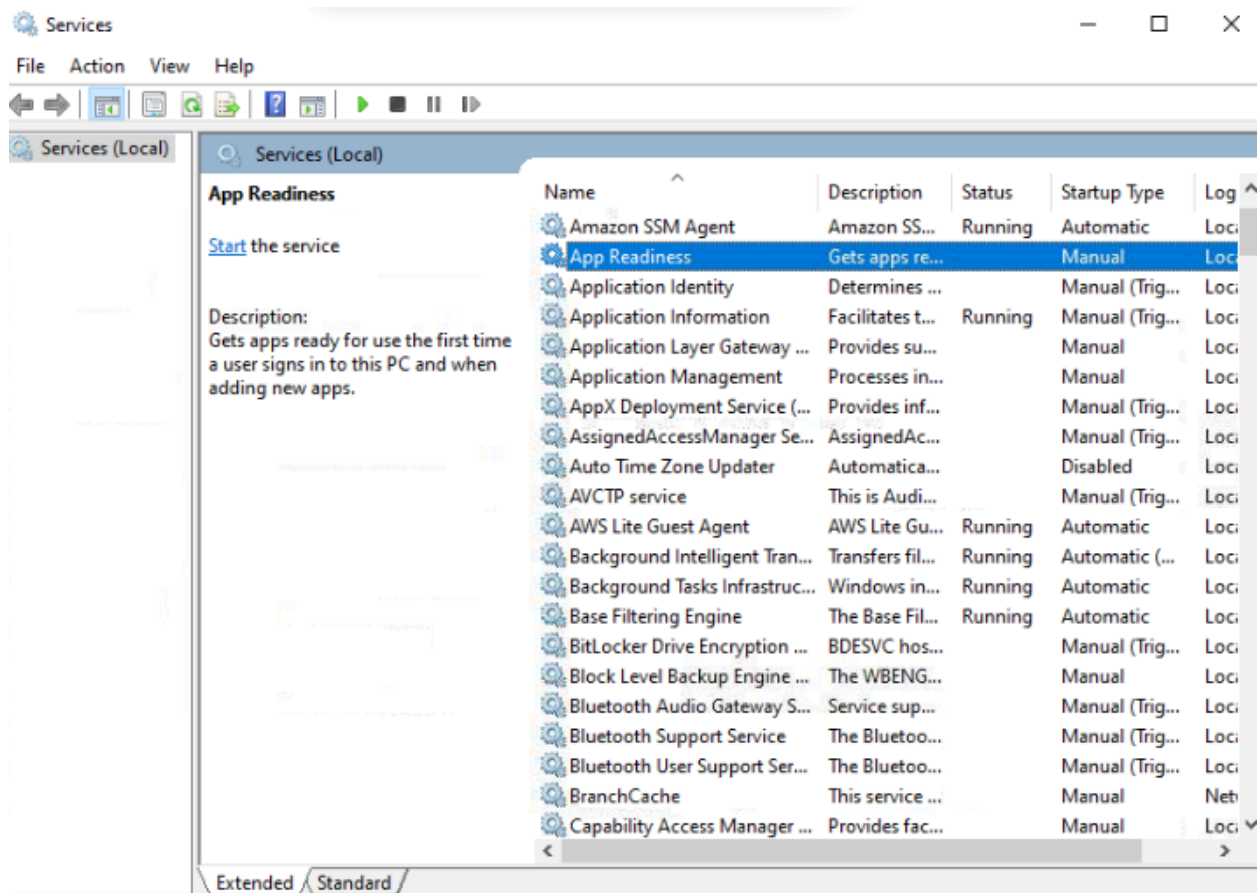


Telemetry: Telemetry is a data collection system used by Microsoft to enhance the user experience by preemptively identifying security and functional issues in software. An application seamlessly shares data (crash logs, application-specific) with Microsoft to improve the user experience for future releases. Telemetry functionality is achieved by Universal Telemetry Client (UTC) services available in Windows and runs through `diagtrack.dll`. Contents acquired through telemetry service are stored encrypted in a local folder `%ProgramData%\Microsoft\Diagnosis` and sent to Microsoft after 15 minutes or so. We can access `The DiagTrack` through the Services console in Windows 10.



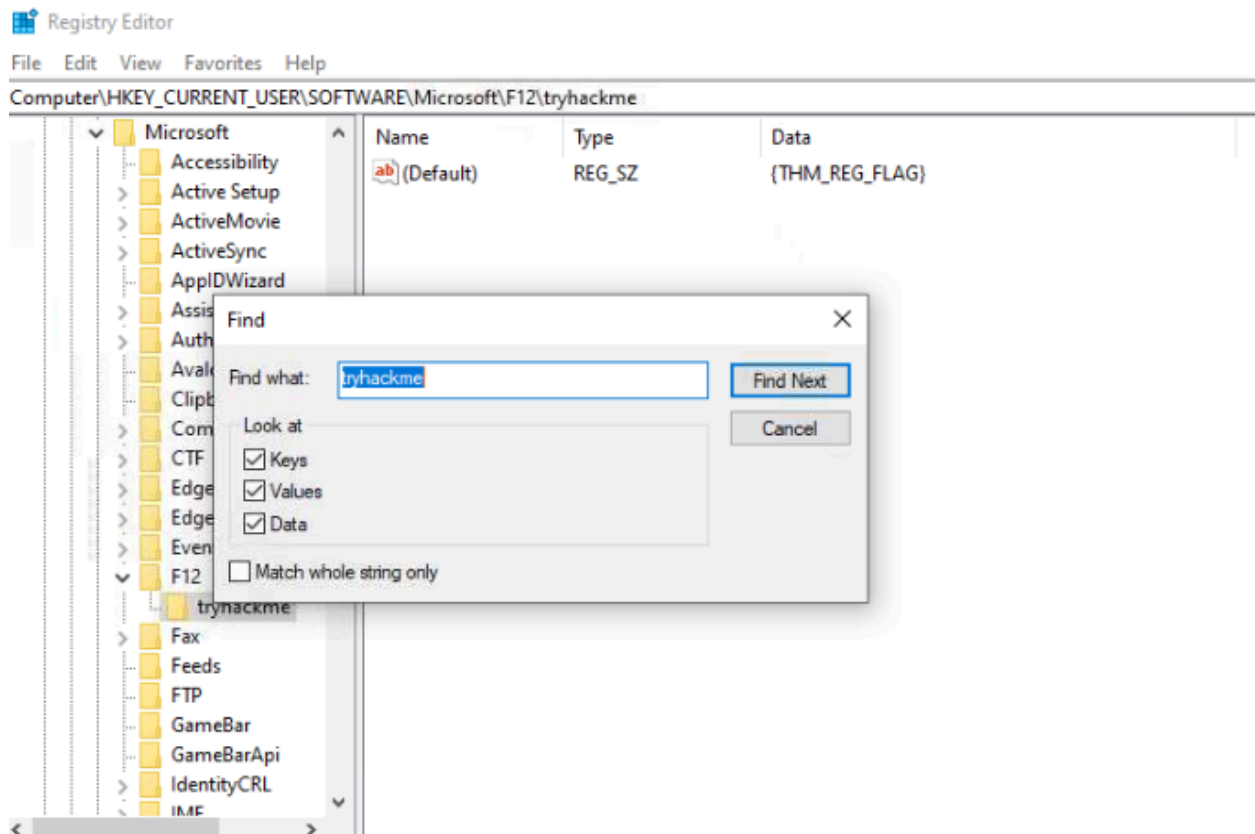
What is the startup type of App Readiness service in the services panel?

Manual



Open Registry Editor and find the key "tryhackme". What is the default value of the key?

{THM_REG_FLAG}



Open the Diagnosis folder and go through the various log files. Can you find the flag?

{THM_1000710}

```

Microsoft Windows [Version 10.0.19042.508]
(c) 2020 Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd %ProgramData%\Microsoft\Diagnosis

C:\ProgramData\Microsoft\Diagnosis>dir
Volume in drive C has no label.
Volume Serial Number is CADE-80F7

Directory of C:\ProgramData\Microsoft\Diagnosis

06/16/2026  11:37 PM    <DIR>          .
06/16/2026  11:37 PM    <DIR>          ..
09/27/2020  07:34 AM    <DIR>          CustomTraceProfiles
06/16/2026  11:38 PM    <DIR>          DownloadedScenarios
06/16/2026  11:52 PM    <DIR>          DownloadedSettings
09/27/2020  07:34 AM    <DIR>          ETLLogs
12/22/2025  01:29 PM             106,496 EventStore.db
06/16/2026  11:37 PM             32,768 EventStore.db-shm
06/17/2026  12:11 AM          1,048,576 EventStore.db-wal
09/27/2020  07:34 AM    <DIR>          EventTranscript
06/16/2026  11:37 PM    <DIR>          FeedbackHub
06/25/2022  02:50 AM             13 flag.txt.txt
09/27/2020  07:34 AM    <DIR>          LocalTraceStore
06/16/2026  11:37 PM             10 osver.txt
06/16/2026  11:37 PM              0 parse.dat
09/15/2022  04:25 AM    <DIR>          ScenariosSqlStore
09/27/2020  07:34 AM    <DIR>          Sideload
09/27/2020  07:34 AM    <DIR>          SoftLanding
09/27/2020  07:34 AM    <DIR>          SoftLandingStage
06/16/2026  11:37 PM    <DIR>          Temp
09/27/2020  07:39 AM    <DIR>          TenantStorage
06/16/2026  11:37 PM    <DIR>          TimeTravelDebuggingStorage
        6 File(s)          1,187,863 bytes
       16 Dir(s)    1,651,703,808 bytes free

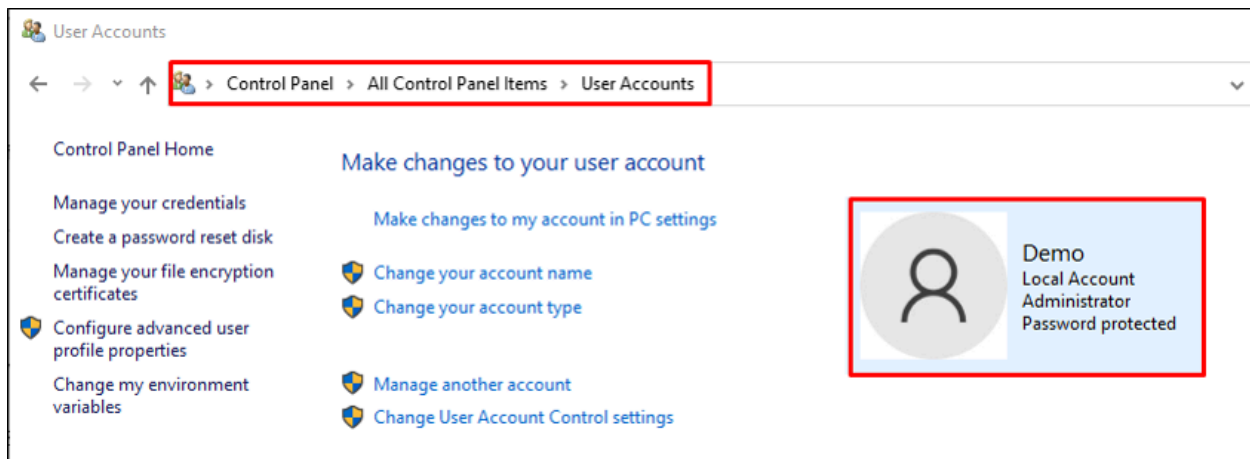
C:\ProgramData\Microsoft\Diagnosis>

C:\ProgramData\Microsoft\Diagnosis>type flag.txt.txt
{THM_1000710}
C:\ProgramData\Microsoft\Diagnosis>

```

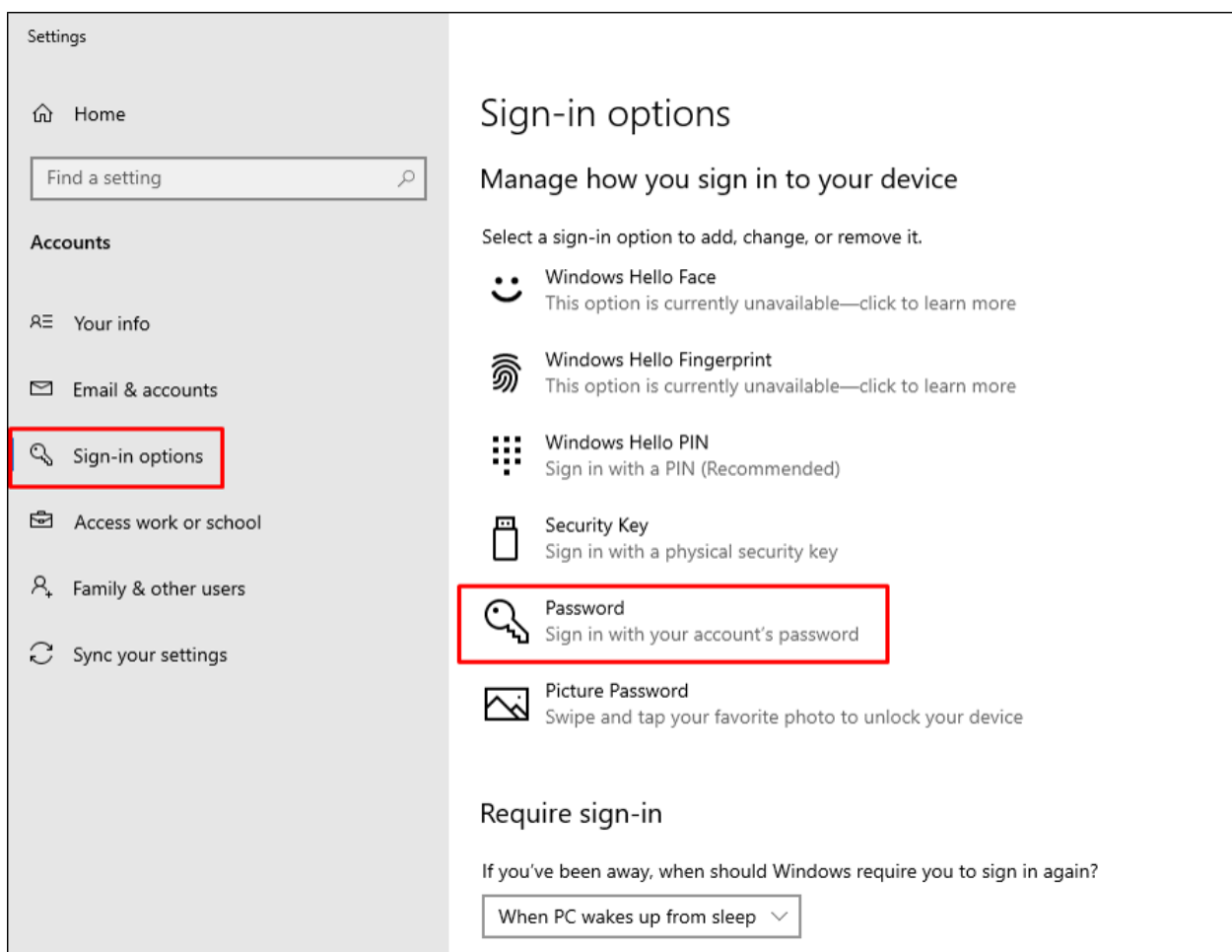
Task 3 - Identity & Access Management

Standard vs Admin Account: Identity and access management involves employing best practices to ensure that only authenticated and authorised users can access the system. There are two types of accounts in Windows, i.e. Admin and Standard Account. Per best practice, the Admin account should only be used to carry out tasks like software installation and accessing the registry editor, service panel, etc. Routine functions like access to regular applications, including Microsoft Office, browser, etc., can be allowed to standard accounts. Go to **Control Panel > User Accounts** to create standard or administrator accounts.

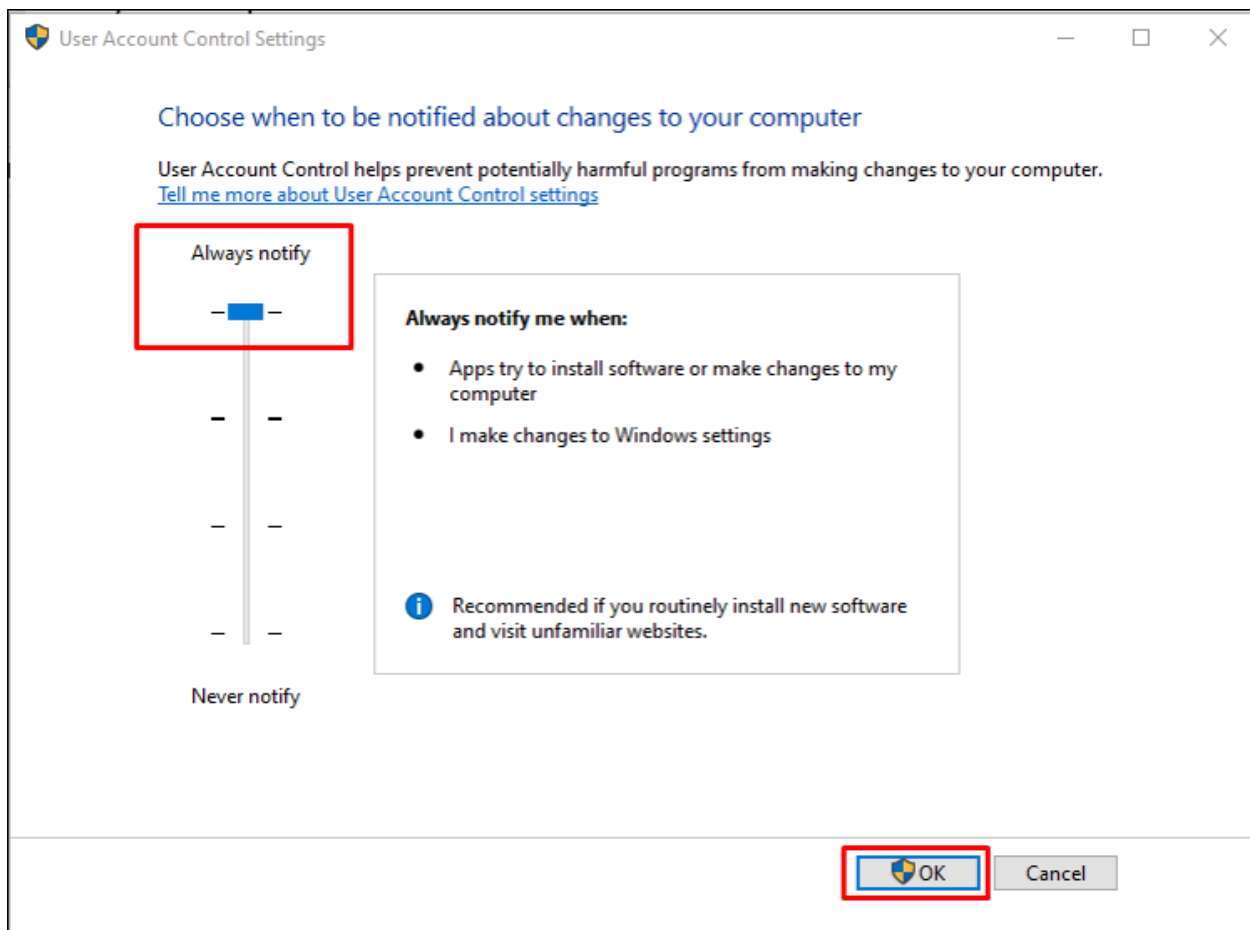


To access accounts and select the sign-in option, go to

Settings > Accounts > Sign-in Options.



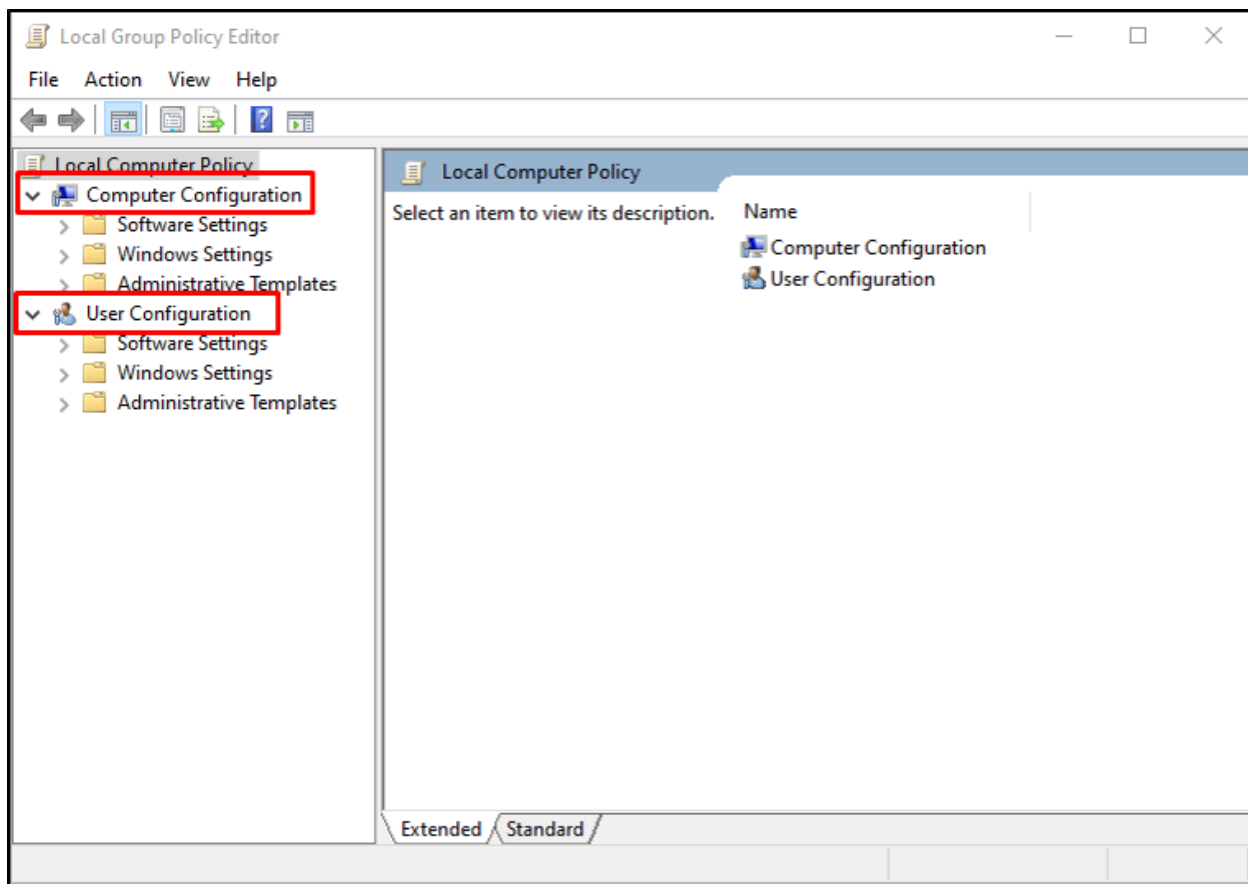
User Account Control (UAC): User Account Control (UAC) is a feature that enforces enhanced access control and ensures that all services and applications execute in non-administrator accounts. It helps mitigate malware's impact and minimises privilege escalation by bypassing UAC. Actions requiring elevated privileges will automatically prompt for administrative user account credentials if the logged-in user does not already possess these. To access UAC, go to **Control Panel -> User Accounts** and click on **Change User Account Control Setting**.



Keep the notification level "**Always Notify**" in the User Account Control Settings.

Local Policy and Group Policies Editor: Group Policy Editor is a built-in interactive tool by Microsoft that allows to configure and implement local and group policies. We mainly use this feature when part of a network; however, we can also use it for a workstation to limit the execution of vulnerable extensions, set password policies, and other administrative settings.

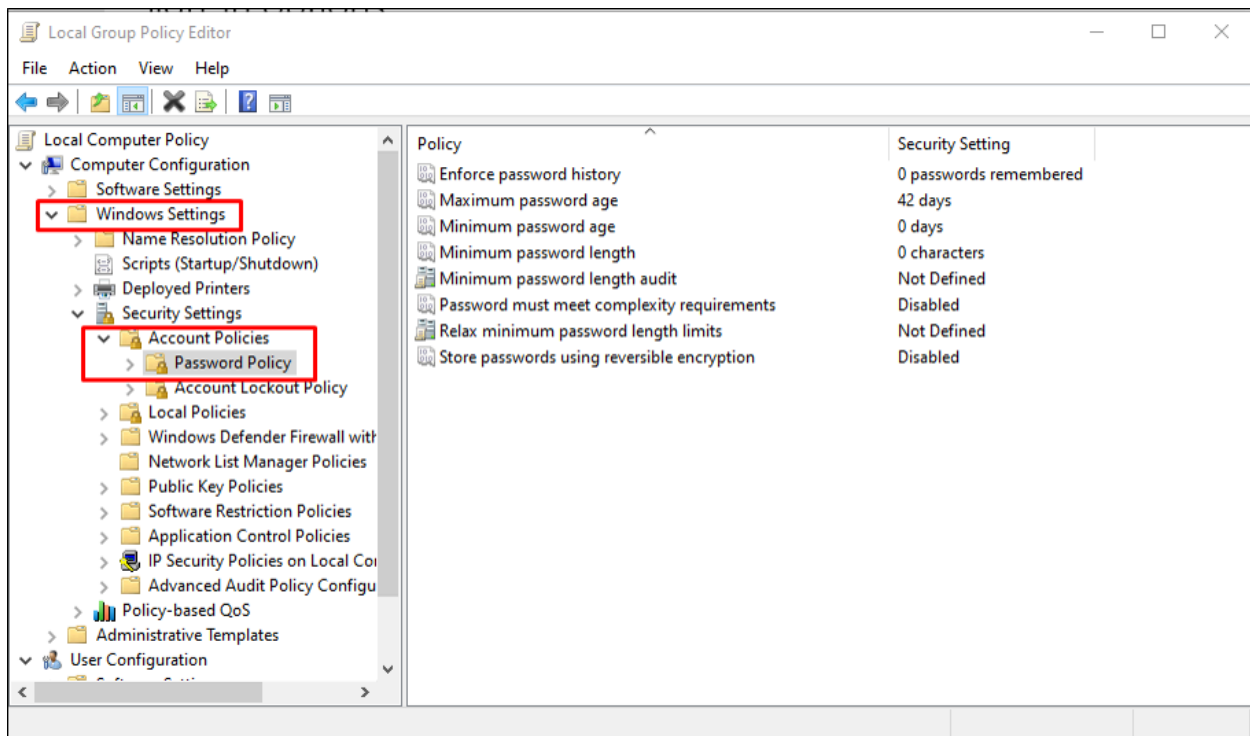
Note: The feature is not available in Windows Home but only in the Pro and Enterprise versions.



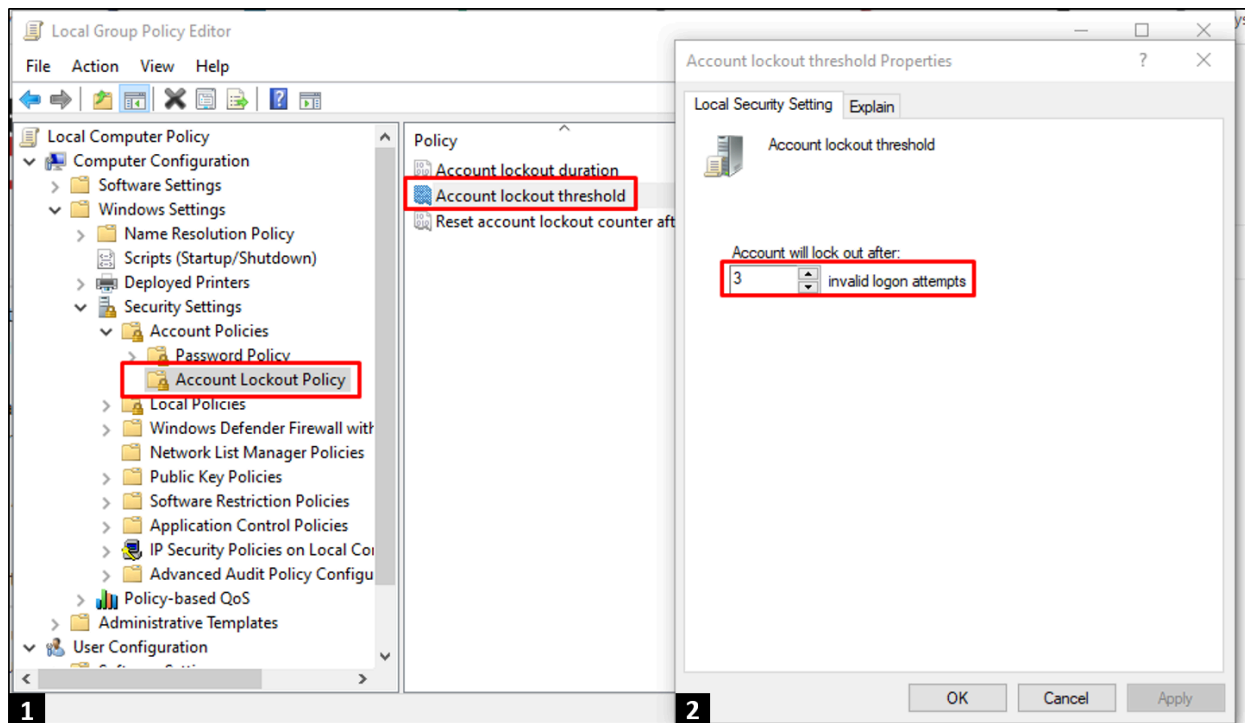
Password Policies: One primary use of a local policy editor is to ensure complex and strong passwords for user accounts. For example, we can design password policies to maximise our security:

- Passwords must contain both uppercase and lowercase characters.
- Check passwords against leaked or already hacked databases or a dictionary of compromised passwords.
- In case of 6 failed login attempts within 15 minutes, the account will remain locked for at least 1 hour.

We can access Password policies through the Local group policy editor. Go to [Security settings > Account Policies > Password policy](#)

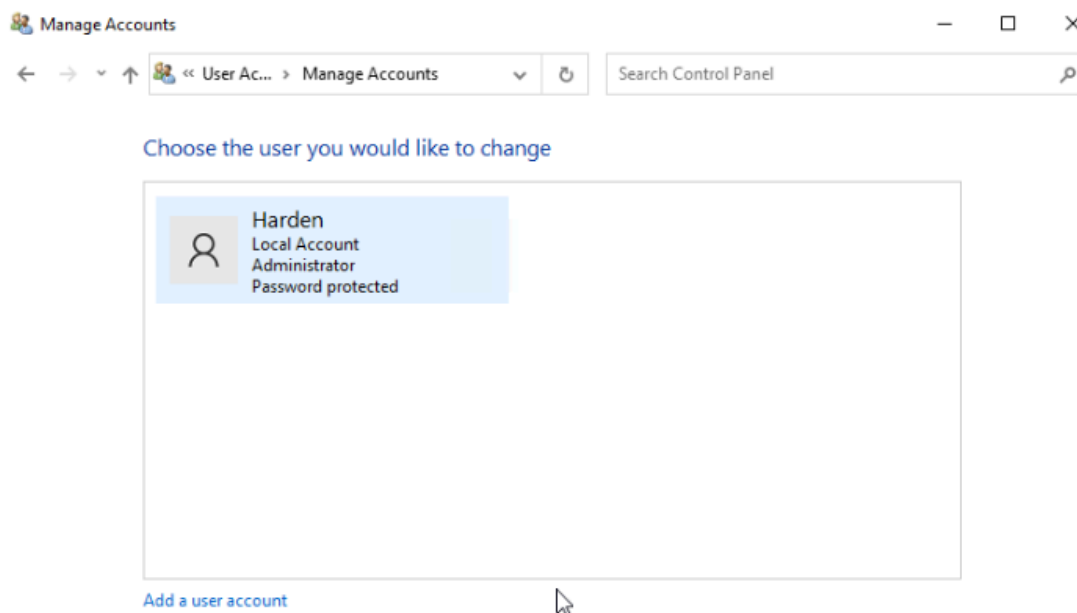


Setting A Lockout Policy: To protect your system password from being guessed by an attacker, we can set out a lockout policy so the account will automatically lock after certain invalid attempts. To set a lockout policy, go to **Local Security Policy > Windows Settings > Account Policies > Account Lockout Policy** and configure values to lock out hackers after three invalid attempts.



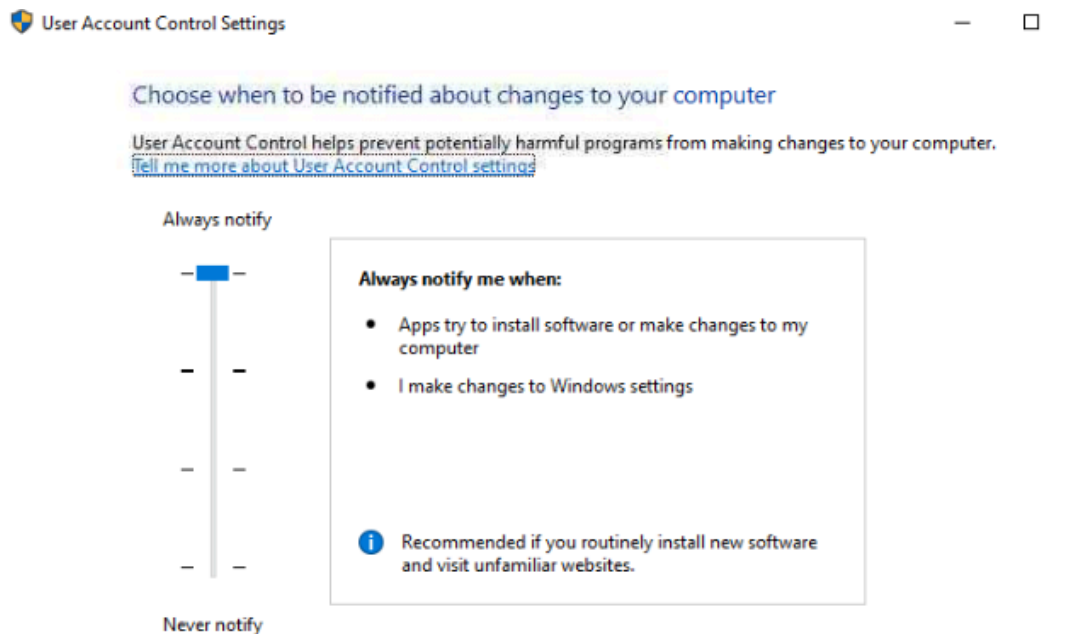
Find the name of the Administrator Account of the attached VM.

Harden



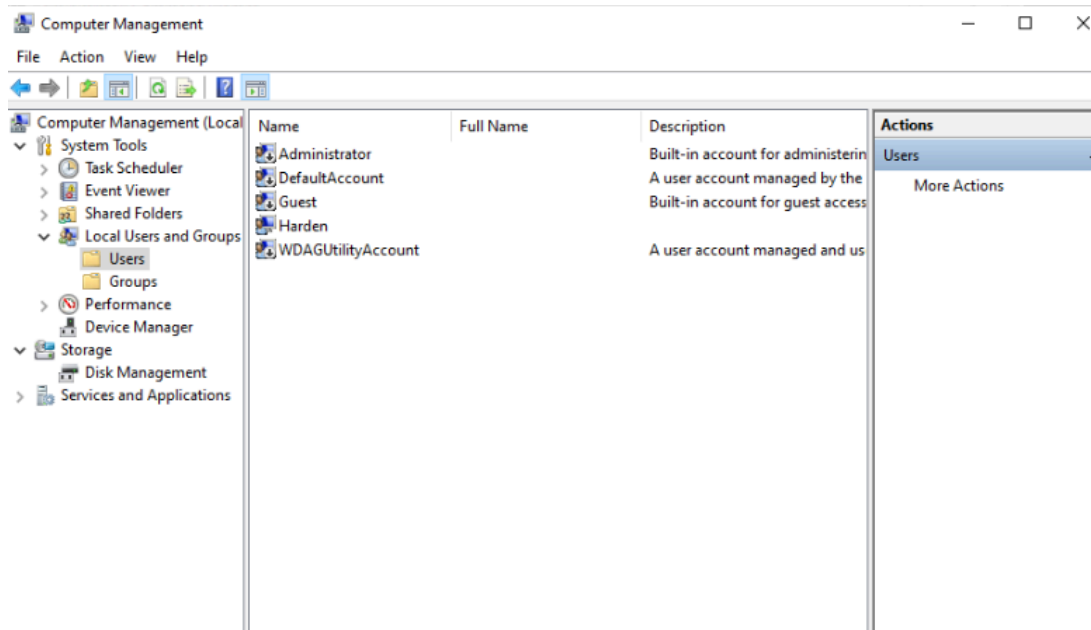
Go to the User Account Control Setting Panel (Control Panel > All Control Panel Items > User Accounts). What is the default level of Notification?

Always Notify



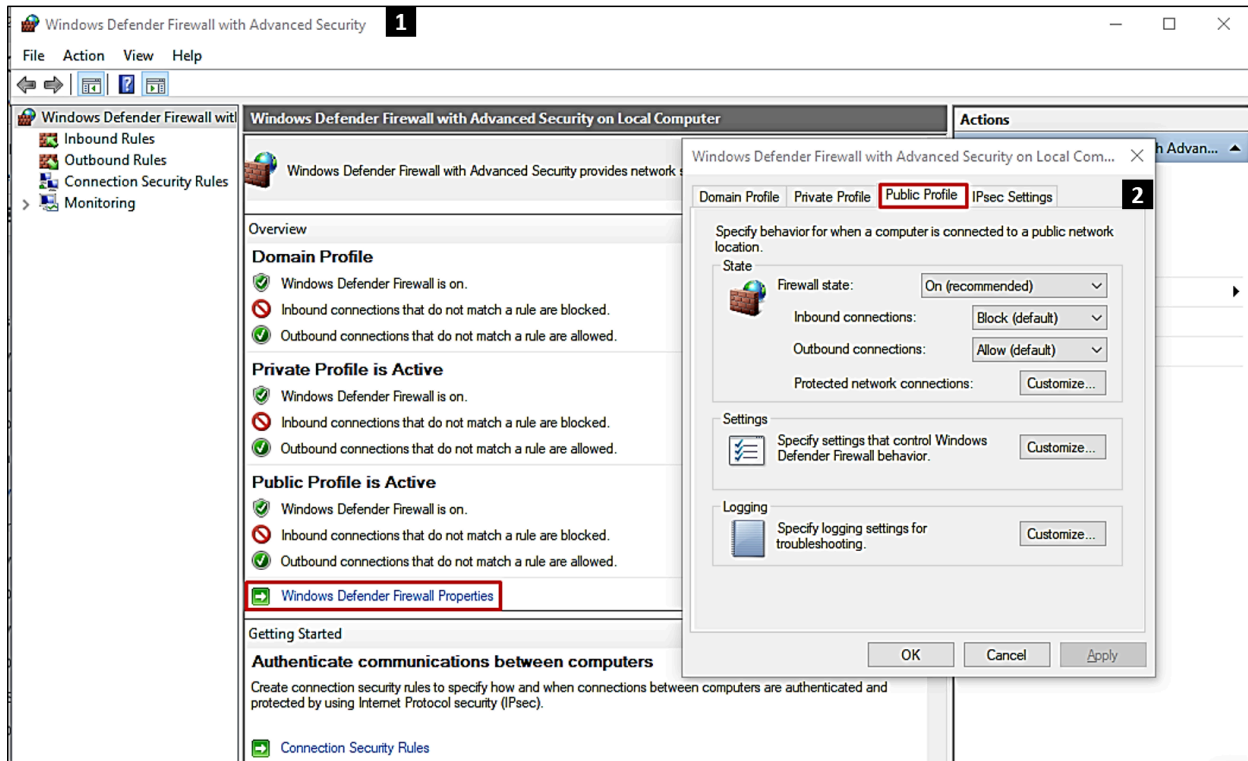
How many standard accounts are created in the VM?

0



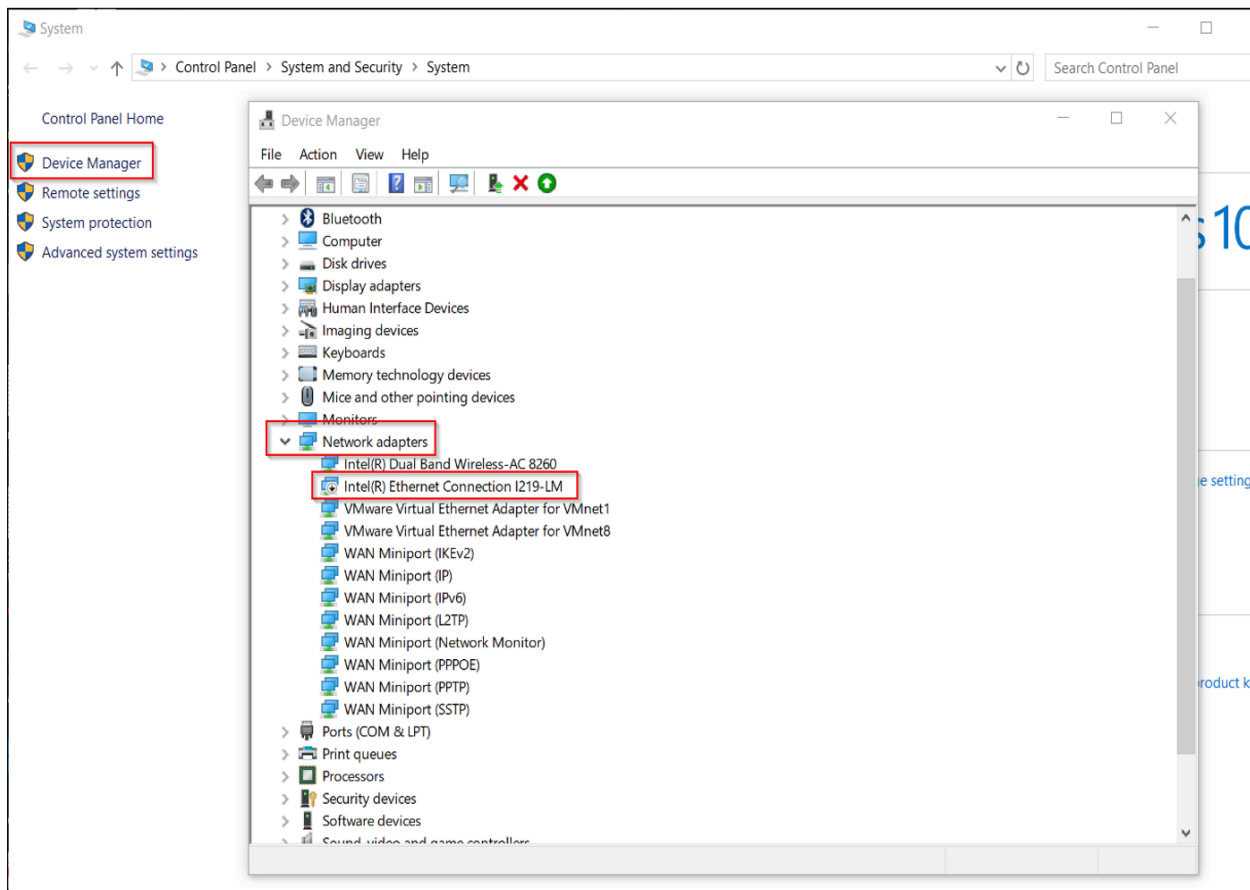
Task 4 - Network Management

Windows Defender Firewall: Windows Defender Firewall is a built-in application that protects computers from malicious attacks and blocks unauthorised traffic through inbound and outbound rules or filters. As an analogy, this is equivalent to “who is coming in and going out of your home”. Malicious actors abuse Windows Firewall by bypassing existing rules. For example, if we have configured the firewall to allow incoming connections, hackers will try to manipulate the functionality by creating a remote connection to the victim's computer. We can access Windows Defender Firewall by accessing `WF.msc` in the Run dialogue.



Whenever possible, enable the Windows Defender Firewall default settings. For blocking all the incoming traffic, always configure the firewall with a 'default deny' rule before making an exception rule that allows more specific traffic.

Disable unused Networking Devices: Network devices like routers, ethernet cards, WiFi adapters etc., enable data sharing between computers. If the device is improperly configured or not being used by the owner, it is recommended to disable the interface so that threat actors cannot access them and use them for data retrieval from the victim's computer. To disable the unused Networking Devices, go to the **Control panel > System and Security Setting > System > Device Manager** and disable all the unused Networking devices.

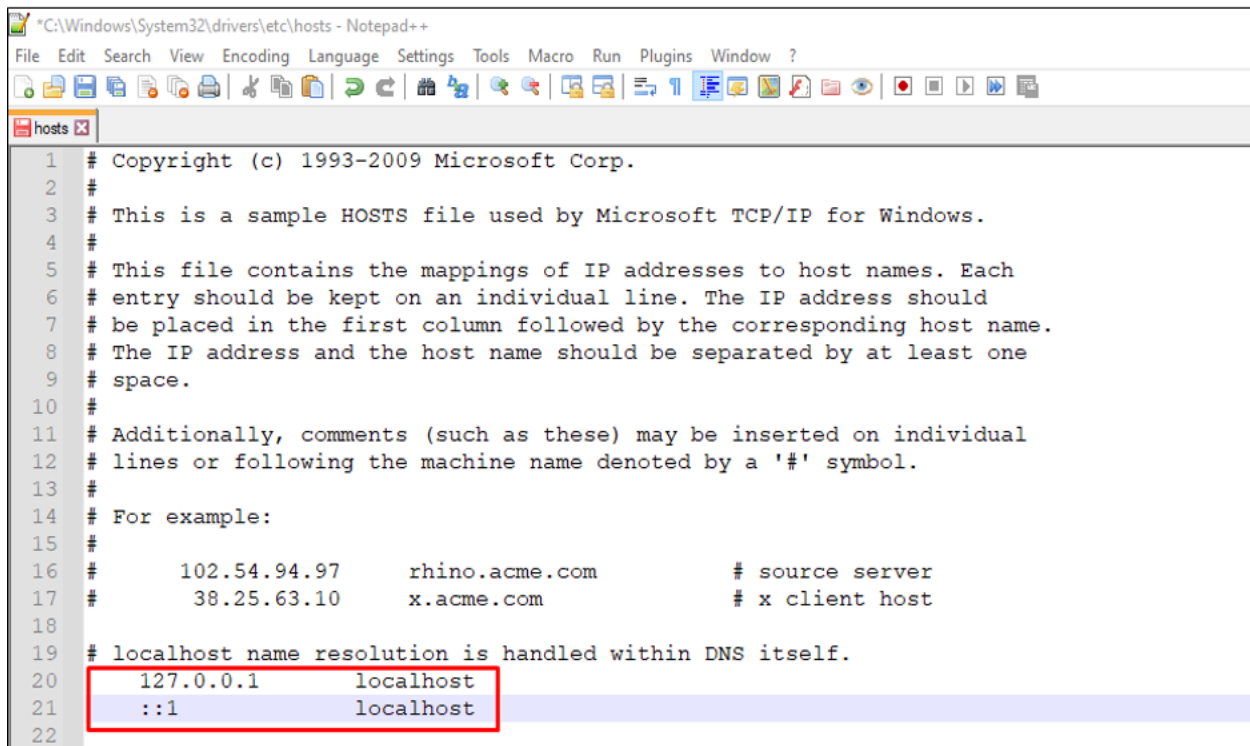


Disable SMB protocol: SMB is a file-sharing protocol exploited by hackers in the wild. The protocol is primarily used for file sharing in a network; therefore, you must disable the protocol if your computer is not part of a network by issuing the following command in PowerShell.

```
user@machine$ Disable-WindowsOptionalFeature -Online -Feature
Name SMB1Protocol
Path      :
Online    : True
RestartNeeded : False
```

Protecting Local Domain Name System (DNS): The domain name system (DNS) is a naming system that translates Fully Qualified Domain Names (FQDN) into IP addresses. If the attacker places himself in the middle, he may intercept and manipulate DNS requests and point them to attacker-controlled systems since DNS replies are neither authenticated nor encrypted. The hosts file located in

Windows acts like local DNS and is responsible for resolving hostnames to IP addresses. Malicious actors try to edit the file's content to reroute traffic to their command and control server. The hosts file is located at `C:\Windows\System32\Drivers\etc\hosts`.

A screenshot of a Notepad++ window showing the contents of the hosts file located at C:\Windows\System32\Drivers\etc\hosts. The window title is "C:\Windows\System32\drivers\etc\hosts - Notepad++". The menu bar includes File, Edit, Search, View, Encoding, Language, Settings, Tools, Macro, Run, Plugins, Window, and ?. The toolbar contains various icons for file operations. The text in the window is as follows:

```
1 # Copyright (c) 1993-2009 Microsoft Corp.
2 #
3 # This is a sample HOSTS file used by Microsoft TCP/IP for Windows.
4 #
5 # This file contains the mappings of IP addresses to host names. Each
6 # entry should be kept on an individual line. The IP address should
7 # be placed in the first column followed by the corresponding host name.
8 # The IP address and the host name should be separated by at least one
9 # space.
10 #
11 # Additionally, comments (such as these) may be inserted on individual
12 # lines or following the machine name denoted by a '#' symbol.
13 #
14 # For example:
15 #
16 #      102.54.94.97      rhino.acme.com          # source server
17 #      38.25.63.10      x.acme.com              # x client host
18
19 # localhost name resolution is handled within DNS itself.
20 # 127.0.0.1      localhost
21 # ::1            localhost
22
```

The last two lines (20 and 21) are highlighted with a red rectangular box.

Mitigating Address Resolution Protocol Attack: The address resolution protocol resolves MAC addresses from given IP addresses saved in the workstations ARP cache. The ARP offers no authentication and accepts responses from any user in the network. An attacker can flood target systems with crafted ARP responses, which point to an attacker-controlled machine and put him in the middle of communication between the targeted hosts. You can check ARP entries using the command `arp -a` in the command prompt.

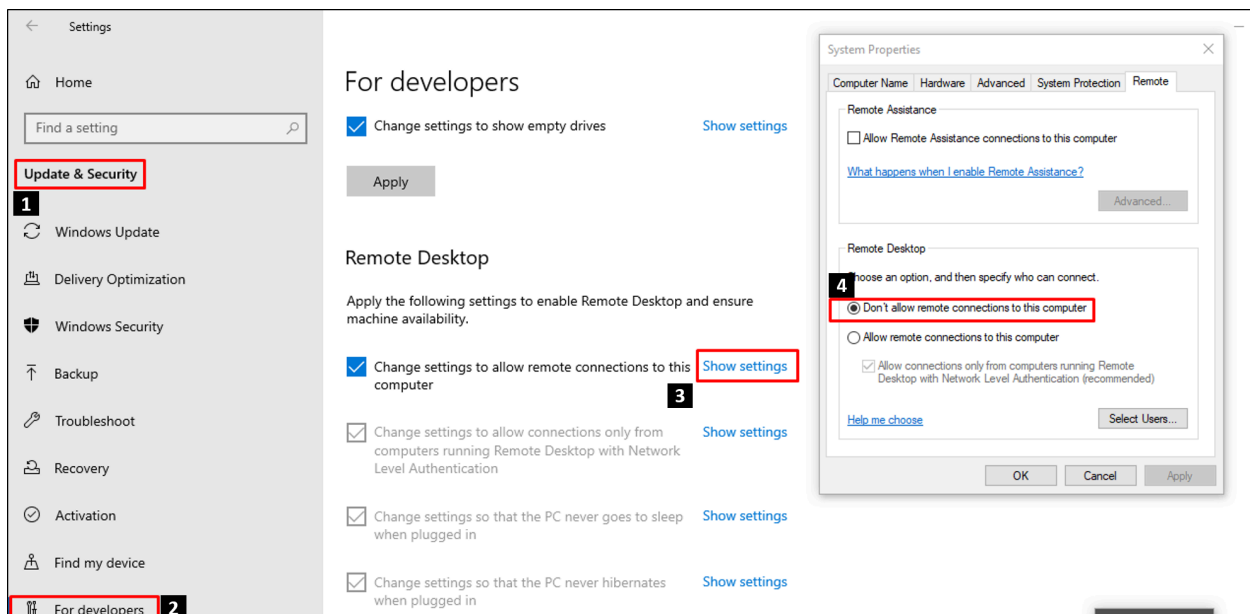
```
user@machine$ arp -a
Interface: 192.168.231.2 --- 0x5

Internet Address      Physical Address      Type
192.168.231.255      ff-ff-ff-ff-ff-ff    static
224.0.0.2             01-00-5e-00-00-02    static
224.0.0.22           01-00-5e-00-00-16    static
```

224.0.0.251	01-00-5e-00-00-fb	static
224.0.0.252	01-00-5e-00-00-fc	static
239.255.255.250	01-00-5e-7f-ff-fa	static

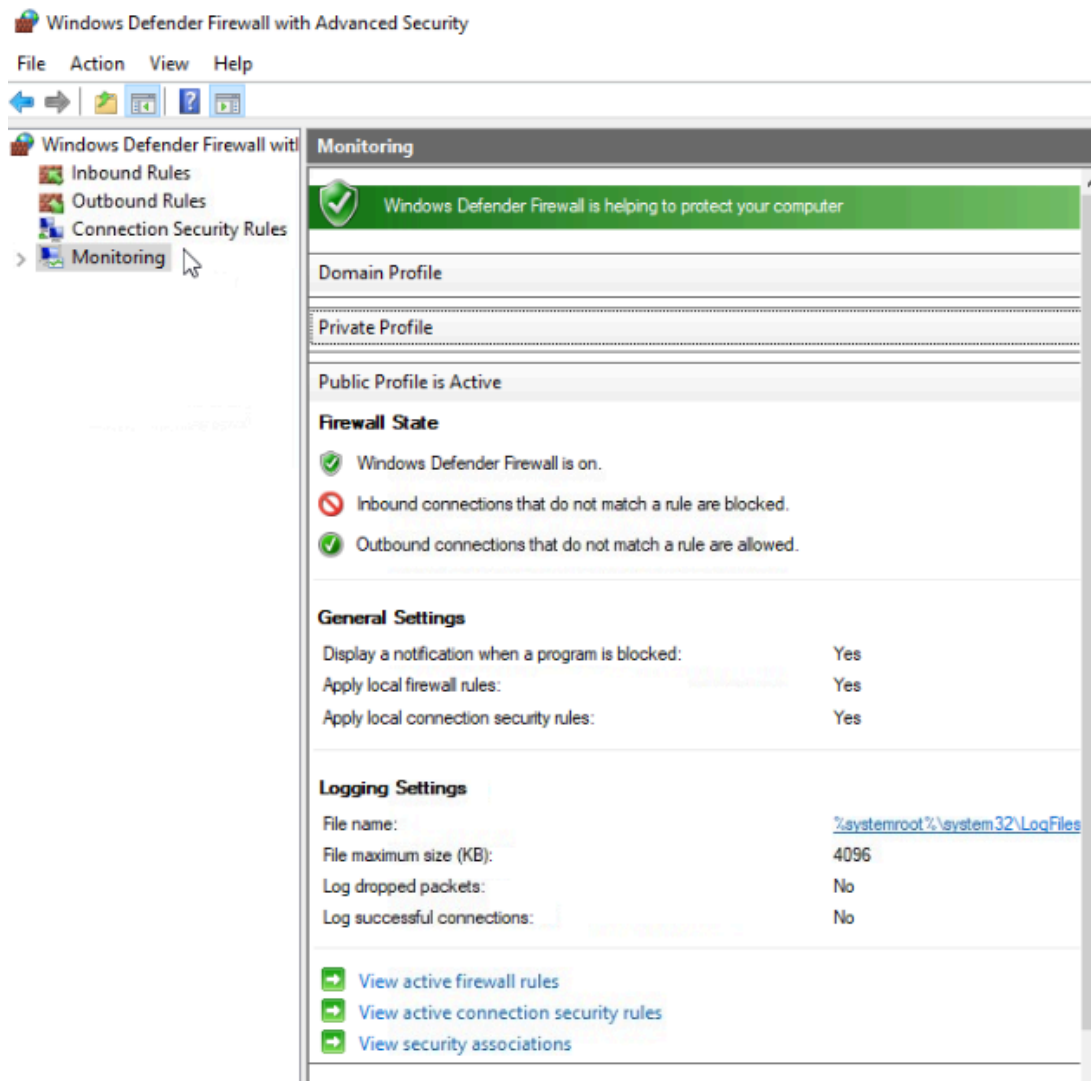
The table contains MAC addresses in the middle and IP addresses in the left. If the table includes a MAC mapped to two IPs, you are probably susceptible to an ARP poisoning attack. To clear the ARP cache and prevent the attack, issue the command `arp -d`.

Preventing Remote Access to Machine: Remote access provides a way to connect to other computers/networks even located at a different geographical location for file sharing and remotely make changes to a workstation. Microsoft has developed a Remote Desktop Protocol (RDP) for connecting with other computers. Hackers have exploited the protocol in the past, like the famous Blue Keep vulnerability, to gain unauthorised access to the target system. We must disable remote access (if not required) by going to `settings > Remote Desktop`. Do not attempt this in VM attached to this room.



Open Windows Firewall and click on Monitoring in the left pane - which of the following profiles is active? Domain, Private, Public?

Public



Find the IP address resolved for the website tryhack.me in the Lab Machine as per the local hosts file.

```

C:\ProgramData\Microsoft\Diagnosis>cd C:\Windows\System32\Drivers\etc
C:\Windows\System32\drivers\etc>type hosts
# Copyright (c) 1993-2009 Microsoft Corp.
#
# This is a sample HOSTS file used by Microsoft TCP/IP for Windows.
#
# This file contains the mappings of IP addresses to host names. Each
# entry should be kept on an individual line. The IP address should
# be placed in the first column followed by the corresponding host name.
# The IP address and the host name should be separated by at least one
# space.
#
# Additionally, comments (such as these) may be inserted on individual
# lines or following the machine name denoted by a '#' symbol.
#
# For example:
#
#       102.54.94.97       rhino.acme.com           # source server
#       38.25.63.10       x.acme.com               # x client host
#
# localhost name resolution is handled within DNS itself.
#       127.0.0.1         localhost
#       ::1               localhost
#       192.168.1.140     tryhack.me

```

Open the command prompt and enter `arp -a`. What is the Physical address for the IP address 255.255.255.255?

```

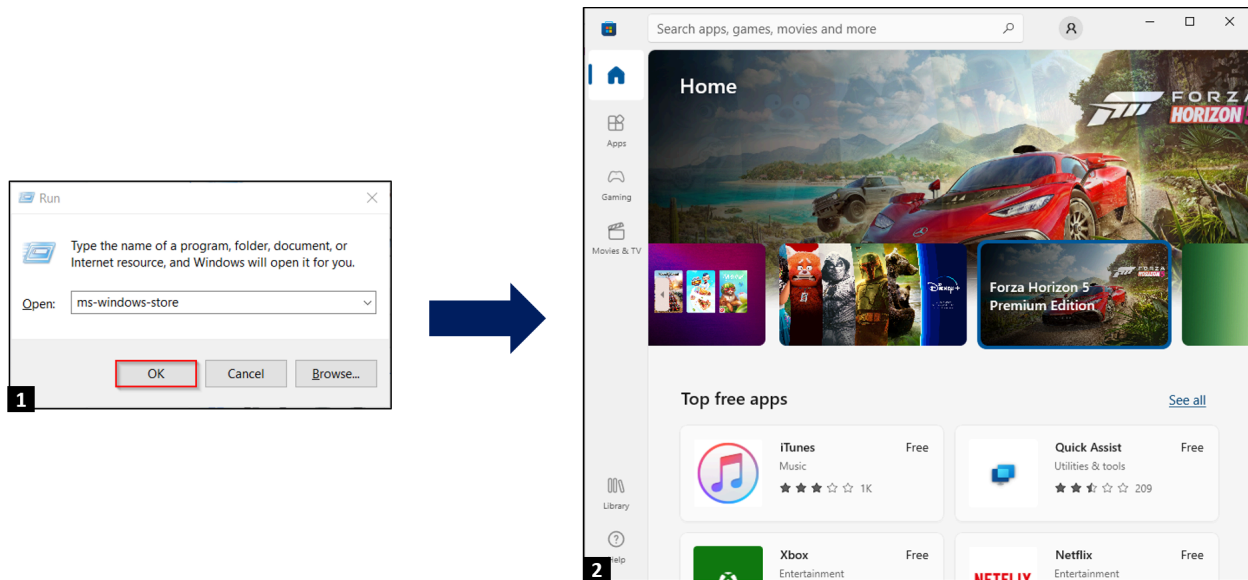
C:\Windows\System32\drivers\etc>arp -a
Interface: 10.114.173.8 --- 0x5
Internet Address      Physical Address      Type
10.114.128.1          0a-19-77-97-cd-0b     dynamic
10.114.139.6          0a-69-8c-83-f1-7b     dynamic
10.114.146.28         0a-8b-5c-90-cf-cd     dynamic
10.114.174.226        0a-14-09-ed-21-e1     dynamic
10.114.191.255        ff-ff-ff-ff-ff-ff     static
169.254.169.254       0a-19-77-97-cd-0b     dynamic
224.0.0.22            01-00-5e-00-00-16     static
224.0.0.251           01-00-5e-00-00-fb     static
224.0.0.252           01-00-5e-00-00-fc     static
239.255.255.250       01-00-5e-7f-ff-fa     static
255.255.255.255       ff-ff-ff-ff-ff-ff     static
C:\Windows\System32\drivers\etc>

```

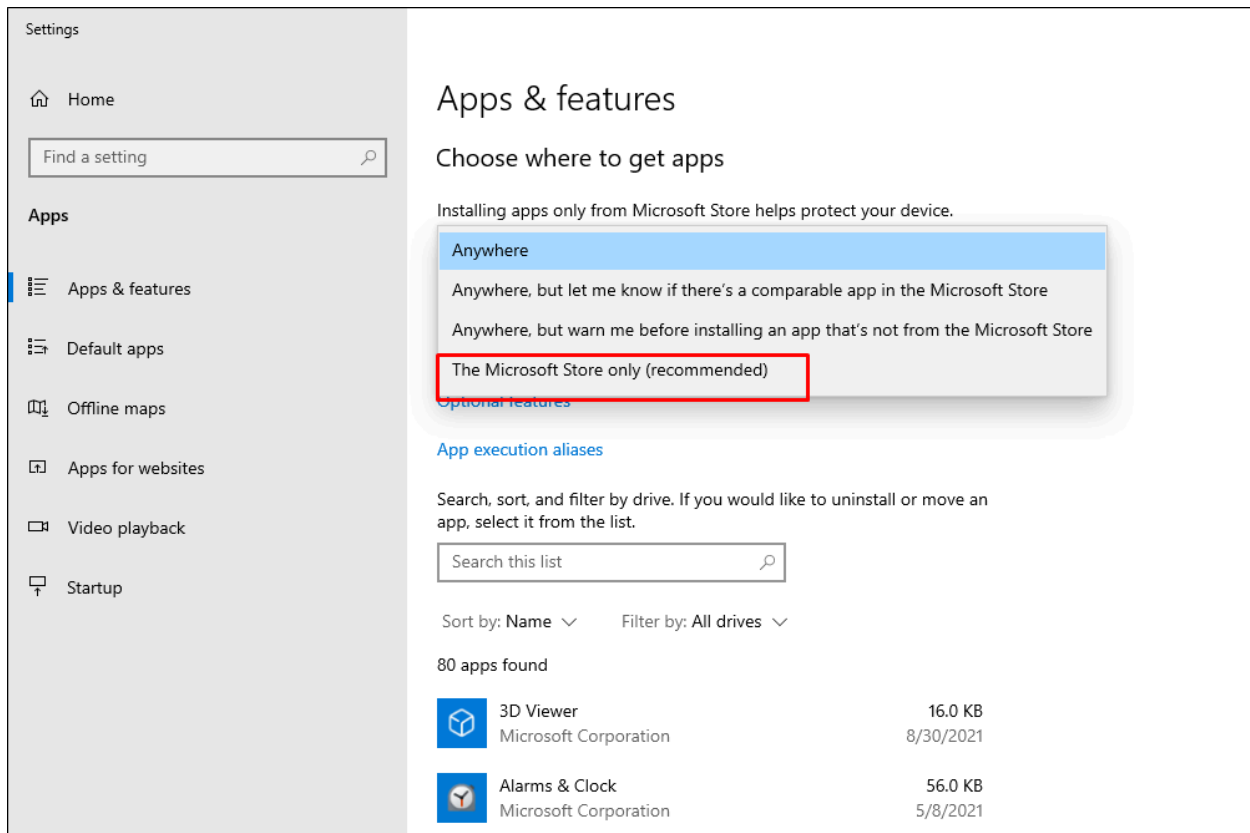
Task 5 - Application Management

Trusted Application Store: Microsoft Store offers a complete range of applications (games, utilities) and allows downloading non-malicious files through a single click. Malicious actors bind legitimate software with trojans and viruses and upload it on the internet to infect and access the victim's computer.

Therefore, downloading applications from the Microsoft Store ensures that the downloaded software is not malicious. We can access Microsoft Application Store by typing `ms-windows-store:` in the Run dialogue.



Safe App Installation: Only allow installation of applications from the Microsoft Store on your computer. Go to `Setting > Select Apps and Features` and then select `The Microsoft Store only`.



Malware Removal through Windows Defender Anti Virus: Windows Defender Anti Virus is a complete anti-malware program capable of identifying malicious programs and taking remedial measures like quarantine. The program used to have an entire Graphical User Interface; however, Windows 10 and newer versions manage the same through Windows Security Centre. Windows Defender primarily offers four main functionalities:

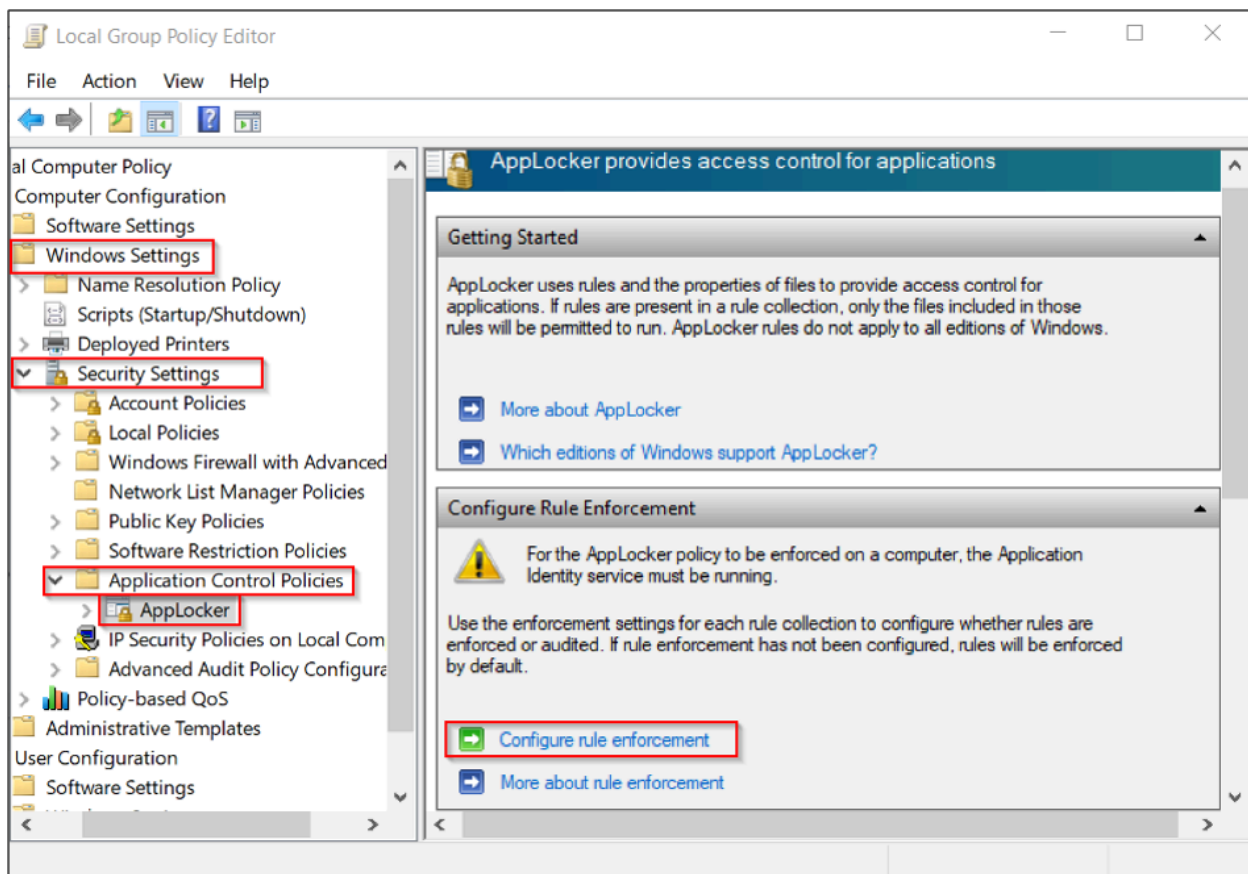
- **Real-time protection** - Enables periodic scanning of the computer.
- **Browser integration** - Enables safe browsing by scanning all downloaded files, etc.
- **Application Guard** Allows complete web session sandboxing to block malicious websites or sessions to make changes in the computer.
- **Controlled Folder Access** - Protect memory areas and folders from unwanted applications.

Microsoft Office Hardening: Microsoft Office Suite is one of the most widely used application suites in all sectors, including financial, telecom, education, etc.

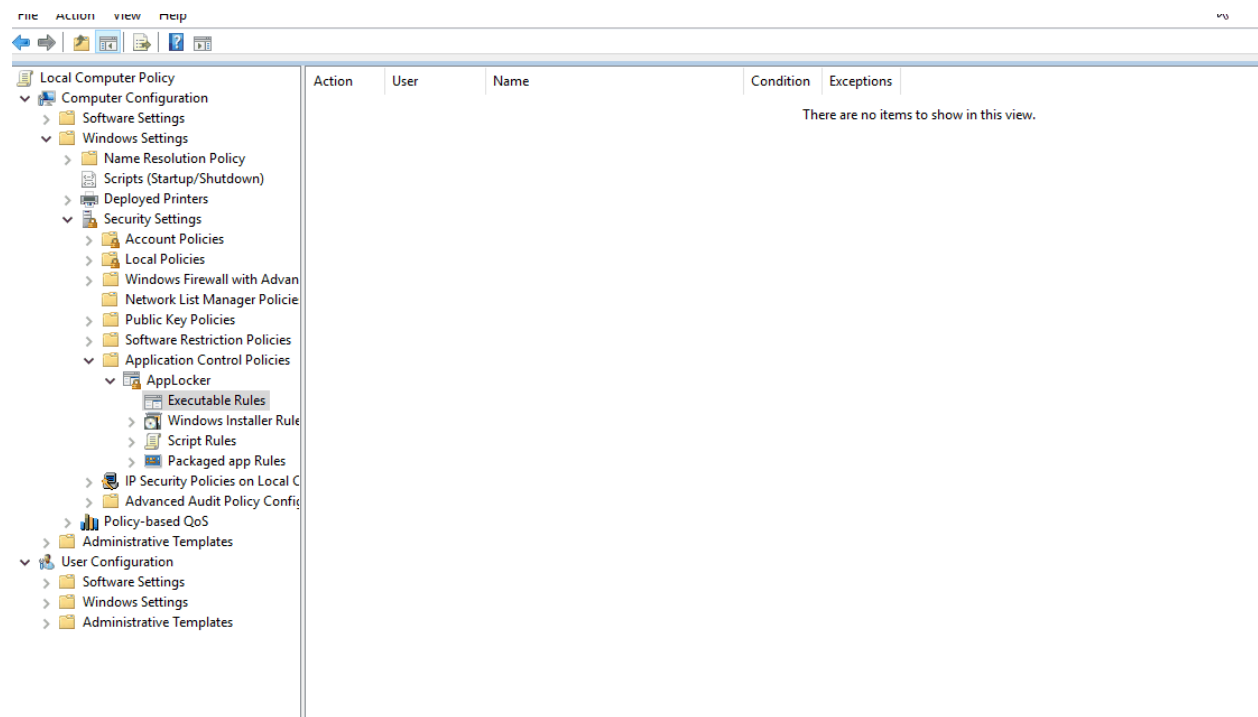
Malicious actors abuse its functionality through macros, Flash applets, object linking etc., to achieve Remote Code Execution. Hardening of Microsoft Office may vary from person to person as legitimate functionality of Microsoft Office is exploited to gain access. For example, disabling macros in a University may be helpful as no one uses it; however, banks cannot disable macros as they heavily rely on complex invoices and formulas through macros.

```
harden@tryhackme$ office.bat (Work in Progress)
Microsoft Office Hardened Successfully.
```

AppLocker: AppLocker is a recently introduced feature that allows users to block specific executables, scripts, and installers from execution through a set of rules. We can easily configure them on a single PC or network through a GUI by the following method:



Now, we will see how to add a rule through AppLocker to block a file based on its publisher name.



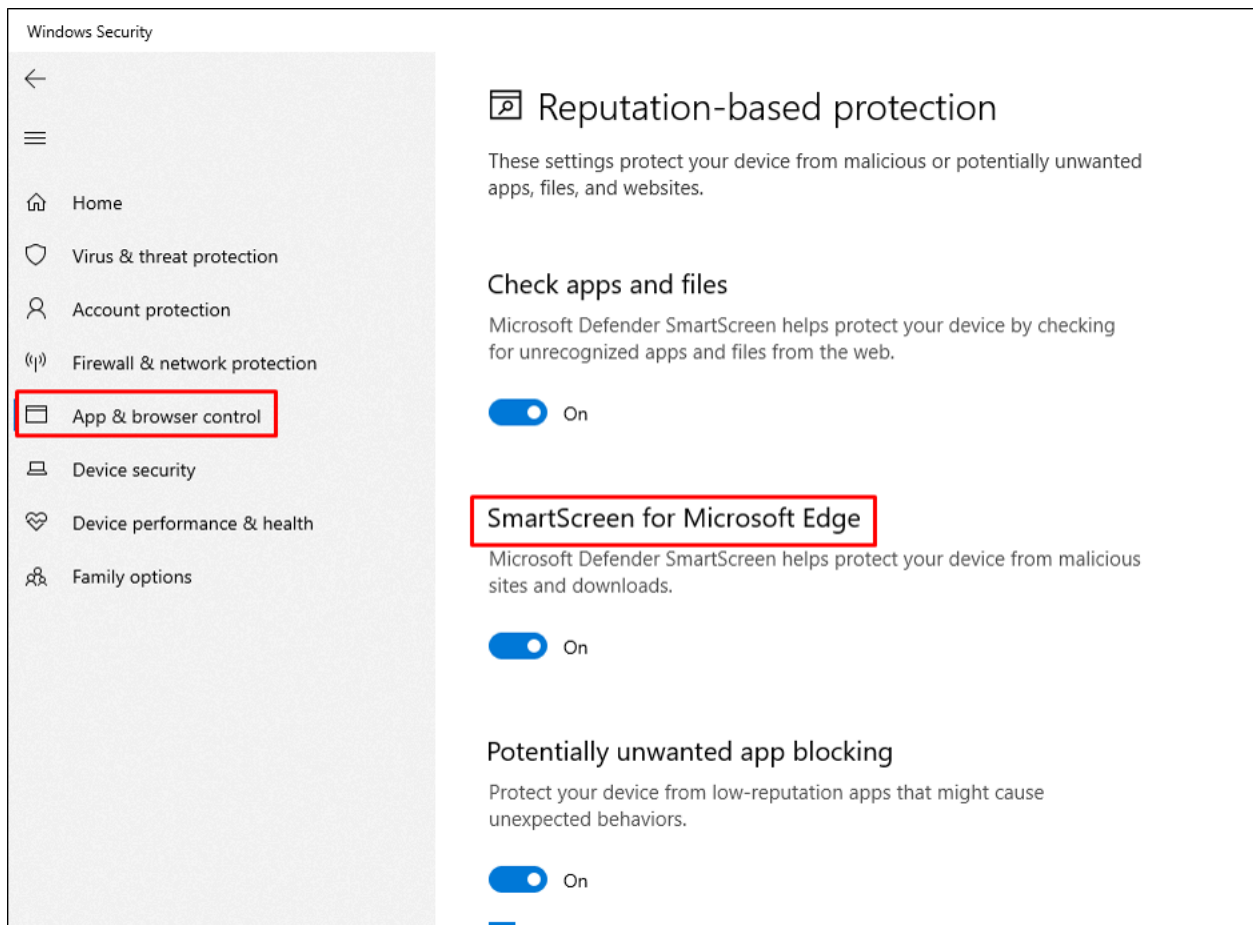
Browser (MS Edge): Microsoft Edge is a built-in browser available on Windows machines based on Chromium, inline with Google Chrome and Brave. The browser often acts as an entry point to a system for further pivoting and lateral movement. It is therefore of utmost importance to block and mitigate critical attacks carried out through a browser that include ransomware, ads, unsigned application downloads and trojans.

Protecting the Browser through Microsoft Smart Screen

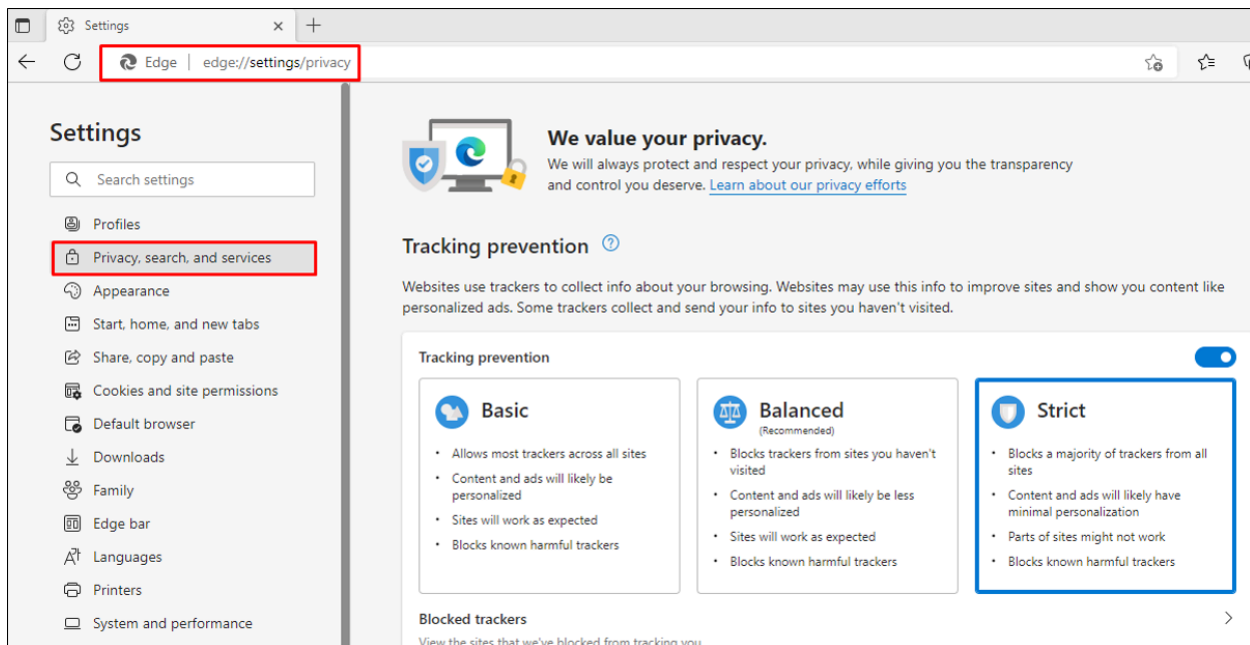
Microsoft SmartScreen helps to protect you from phishing/malware sites and software when using Microsoft Edge. It helps to make informed decisions for downloads and lets you browse safely in Microsoft Edge by:

- Displaying an alert if you are visiting any suspicious web pages.
- Vetting downloads by checking their hash, signature etc against a malicious software database.
- Protecting against phishing and malicious sites by checking visited websites against a threat intelligence database.

To turn on the Smart Screen, go to **Settings > Windows Security > App and Browser Control > Reputation-based Protection** . Scroll down and turn on the **SmartScreen option** .



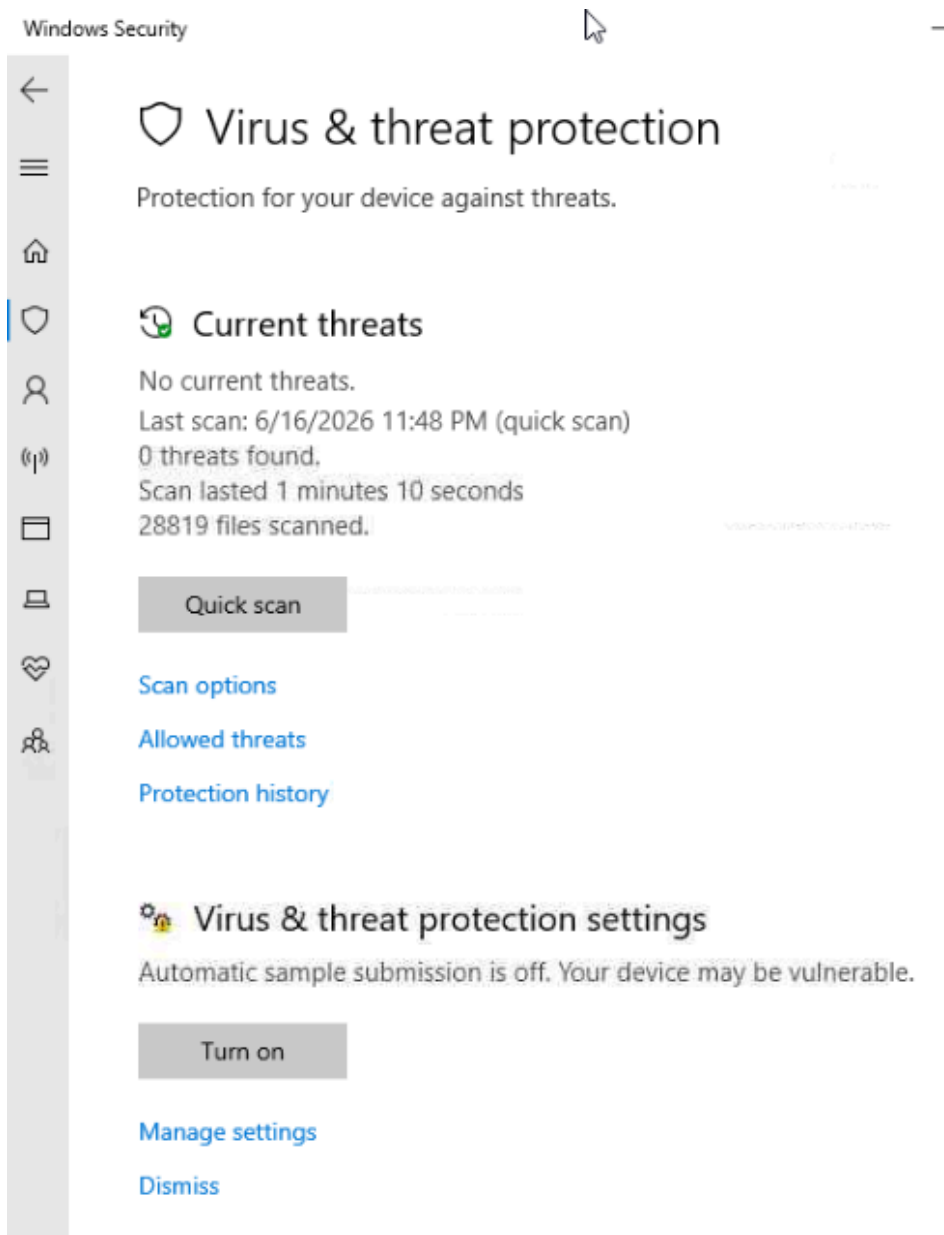
Open Microsoft Edge, go to Settings and then click "**Privacy, Search and Services**" - Set "**Tracking prevention**" to **Strict** to avoid tracking through ads, cookies etc.



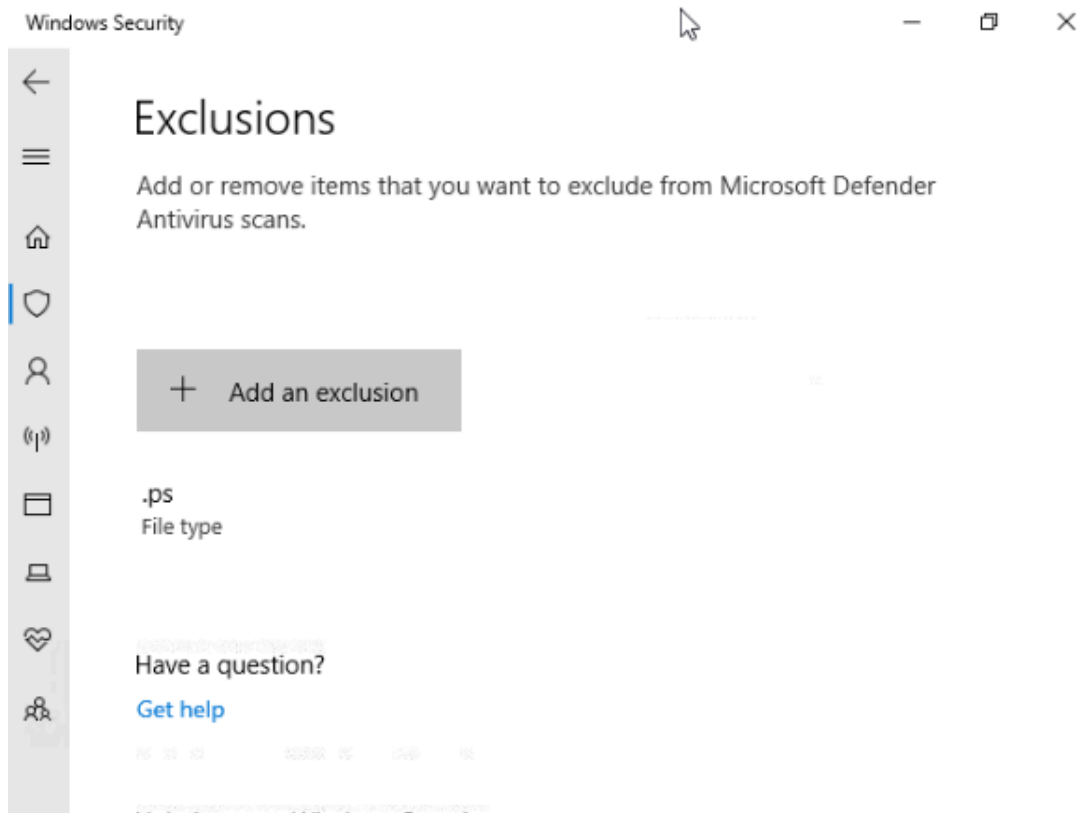
Answer the questions below

Windows Defender Antivirus is configured to exclude a particular extension from scanning. What is the extension?

.ps



Manage Settings > Exclusions



A Word document is received from an unknown email address. It is best practice to open it immediately on your personal computer (yay/nay).

nay

What is the flag you received after executing the Office Hardening Batch file?

{THM_1101110}

```

C:\Users\Harden\Desktop>dir office.bat
Volume in drive C has no label.
Volume Serial Number is CADE-80F7

Directory of C:\Users\Harden\Desktop

06/27/2022  04:09 AM                10,446 office.bat
               1 File(s)                10,446 bytes
               0 Dir(s)  1,660,211,200 bytes free

C:\Users\Harden\Desktop>sc start WinDefend
[SC] StartService FAILED 1056:

An instance of the service is already running.

C:\Users\Harden\Desktop>setx /M MP_FORCE_USE_SANDBOX 1
SUCCESS: Specified value was saved.

C:\Users\Harden\Desktop>"C:\Program Files"\Windows Defender\MpCmdRun.exe - SignatureUpdate
Bad Command line - Command Line - Option should start with '-' or '/' SignatureUpdate

CmdTool: Failed with hr = 0x80070667. Check C:\Users\Harden\AppData\Local\Temp\MpCmdRun.log for more information
CmdTool: Invalid command line argument

C:\Users\Harden\Desktop>"C:\Program Files"\Windows Defender\MpCmdRun.exe -SignatureUpdate
Signature update started . . .

```

```

C:\Users\Harden\Desktop>reg add "HKCU\Software\Microsoft\Office\16.0\Word\Options\WordMail" /v DontUpdateLinks /v
The operation completed successfully.

C:\Users\Harden\Desktop>reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows\DeliveryOptimization" /v DODownloadMod
ERROR: Access is denied.

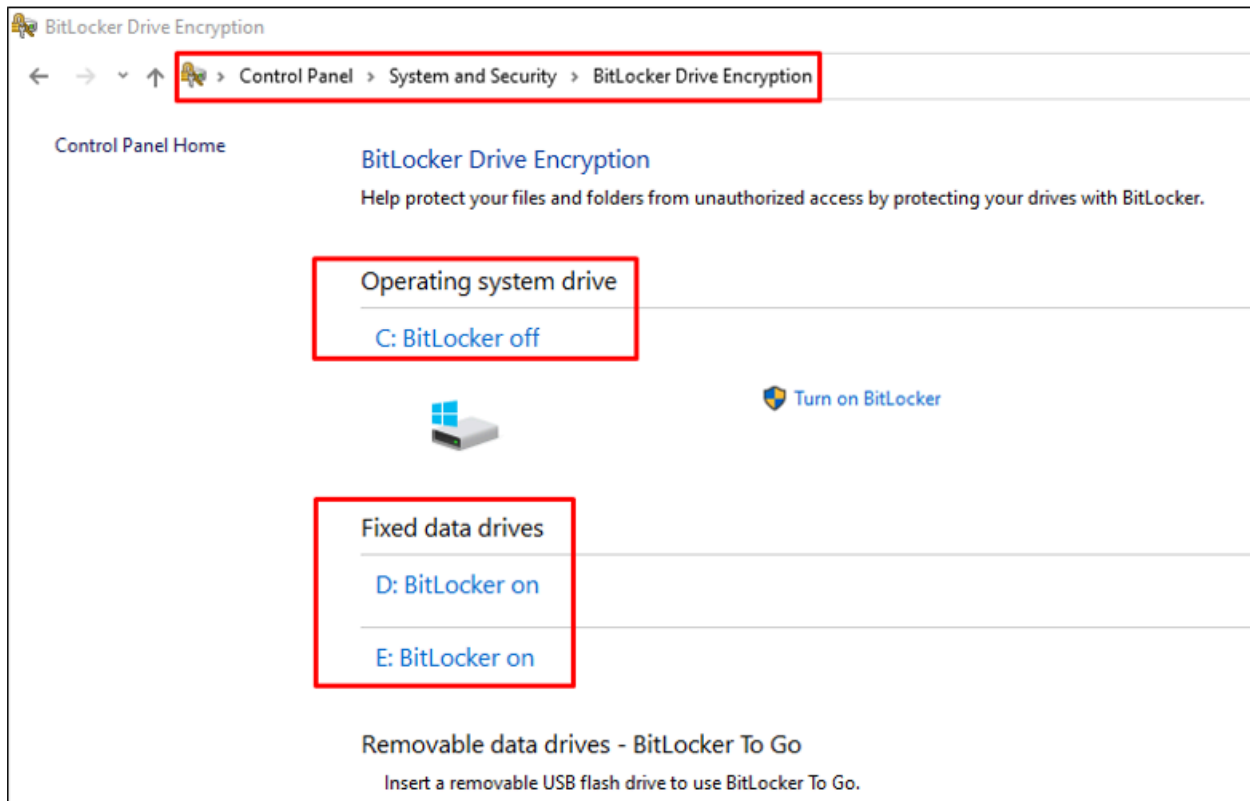
C:\Users\Harden\Desktop>reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\DeliveryOptimization\Config\" /v
/d 1 /f
ERROR: Access is denied.

C:\Users\Harden\Desktop>echo "Microsoft Office Hardened Successfully - Here is your Flag {THM_1101110}"
"Microsoft Office Hardened Successfully - Here is your Flag {THM_1101110}"

```

Task 6 - Storage Management

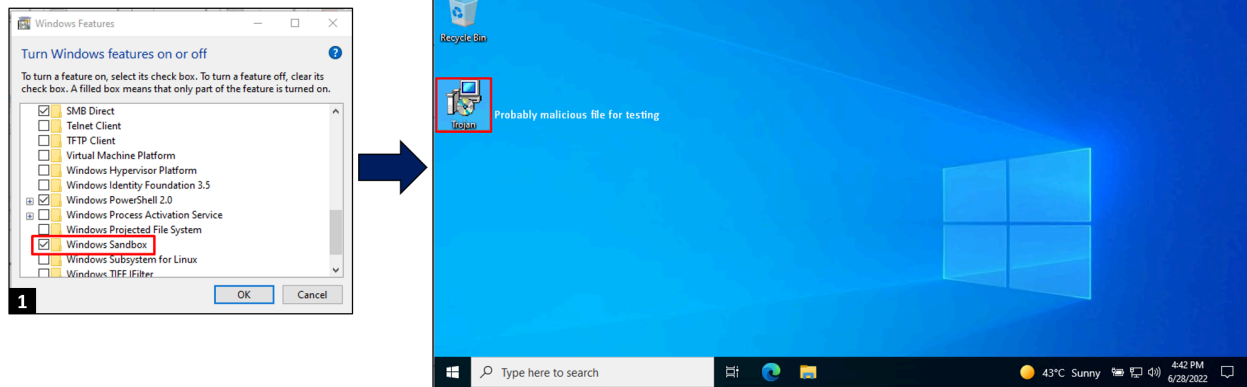
Data Encryption Through BitLocker: Encryption of the computer is one of the most vital things to which we usually pay little attention. The worst nightmare is that someone gets unfettered access to your devices' data. Encryption ensures that you or someone you share the recovery key with can access the stored content. Microsoft, for its business edition of Windows, utilises the encryption tools by BitLocker. Let us have a quick look at how one can ensure to protect the data through BitLocker encryption features available on the Home Editions of Windows 10. Go to **Start > Control Panel > System and Security > BitLocker Drive Encryption**. You can easily see if the option to BitLocker Drive Encryption is enabled or not.



A trusted Platform Module chip TPM is one of the basic requirements to support BitLocker device encryption. Keeping the BitLocker recovery key in a secure place (preferably not on the same computer) is imperative.

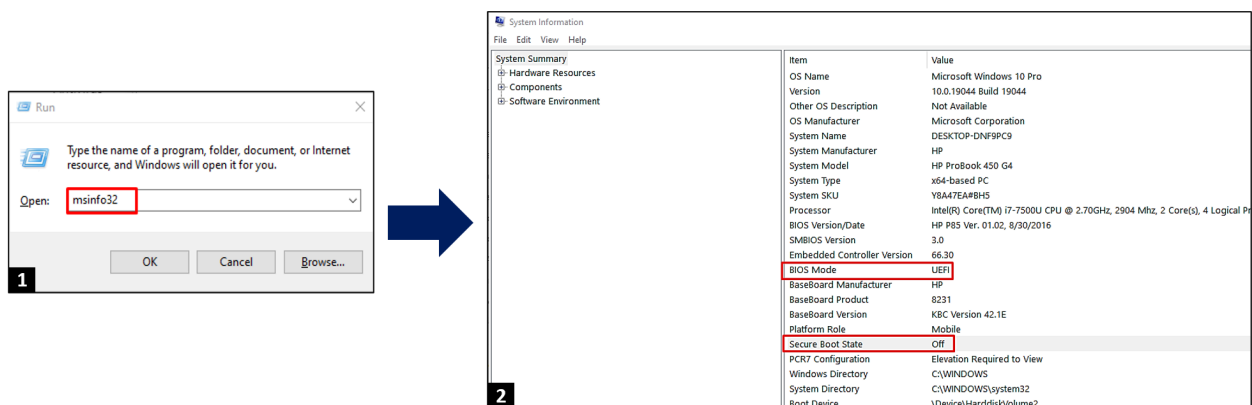
Windows Sandbox: To run applications safely, we can use a temporary, isolated, lightweight desktop environment called Windows Sandbox. We can install software inside this safe environment, and this software will not be a part of our host machine, it will remain sandboxed. Once the Windows Sandbox is closed, everything, including files, software, and states will be deleted. We would require Virtualisation enabled on our OS to run this feature. We cannot try this in the attached VM but the steps for enabling the Sandbox feature are as below:

Click Start > Search for 'Windows Features' and turn it on > Select Sandbox > Click OK to restart



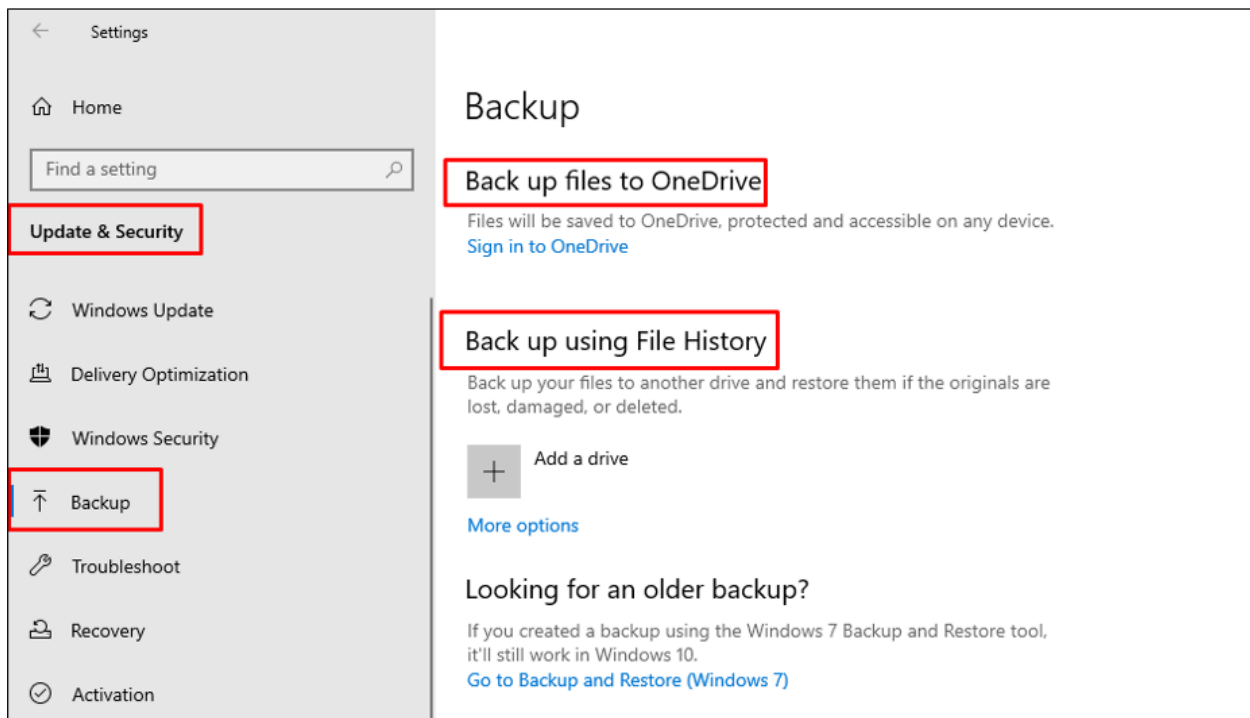
If you want to close the Sandbox, click the **close button**, and it will disappear. Opening suspicious files in a Windows Sandbox before blindly executing them in your base OS is recommended.

Windows Secure Boot: Secure boot – an advanced security standard – checks that your system is running on trusted hardware and firmware before booting, which ensures that your system boots up safely while preventing unauthorised software access from taking control of your PC, like malware. You are already in a secure boot environment if you run a modern PC with Unified Extensible Firmware Interface UEFI (the best replacement for BIOS) or Windows 10. You can check the status of the secure boot by following:



The incredible thing is that you do not need to enable or install it as it works silently in the background. Windows allows you to disable these features, which is not recommended. You can enable Secure boot from BIOS settings (opens in new tab) (if disabled).

Enable File Backups: The last option, but certainly not the least important one to prevent losing irreplaceable and critical files is to enable file backups. Despite all the above techniques, if you somehow lose essential data/files, you can recover the loss by restoring it, if you have a file backup option. Creating file backups is the best option to avoid disasters like malware attacks or hardware failure. You can enable the file backup option through **Settings > Update and Security > Backup** :-

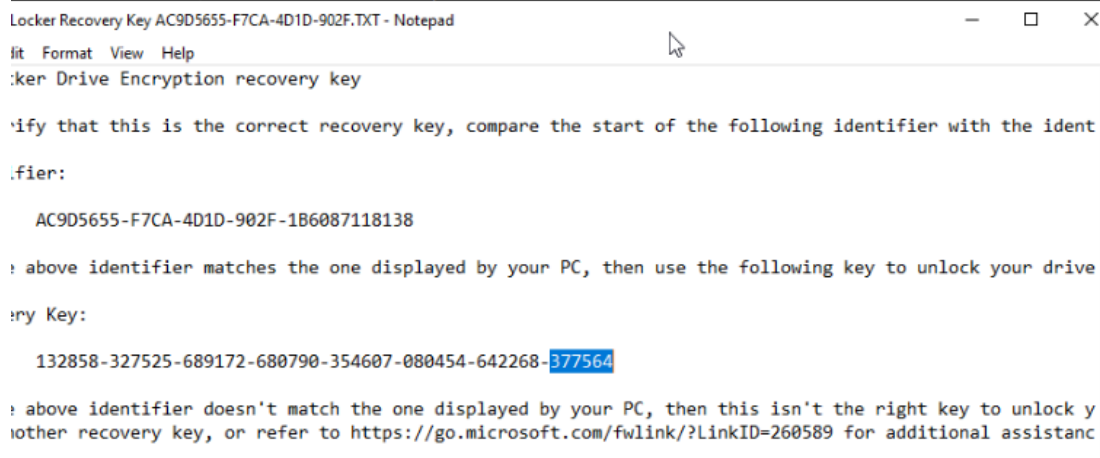


Therefore, the most convenient option is enabling it from the '**File History**' option - a built-in functionality of Windows 10 and 11.

Answer the questions below

A security engineer has misconfigured the attached VM and stored a BitLocker recovery key in the same computer. Can you read the last six digits of the recovery key?

377564



Locker Recovery Key AC9D5655-F7CA-4D1D-902F.TXT - Notepad

File Format View Help

BitLocker Drive Encryption recovery key

Verify that this is the correct recovery key, compare the start of the following identifier with the identifier:

AC9D5655-F7CA-4D1D-902F-1B6087118138

If the above identifier matches the one displayed by your PC, then use the following key to unlock your drive.

Recovery Key:

132858-327525-689172-680790-354607-080454-642268-377564

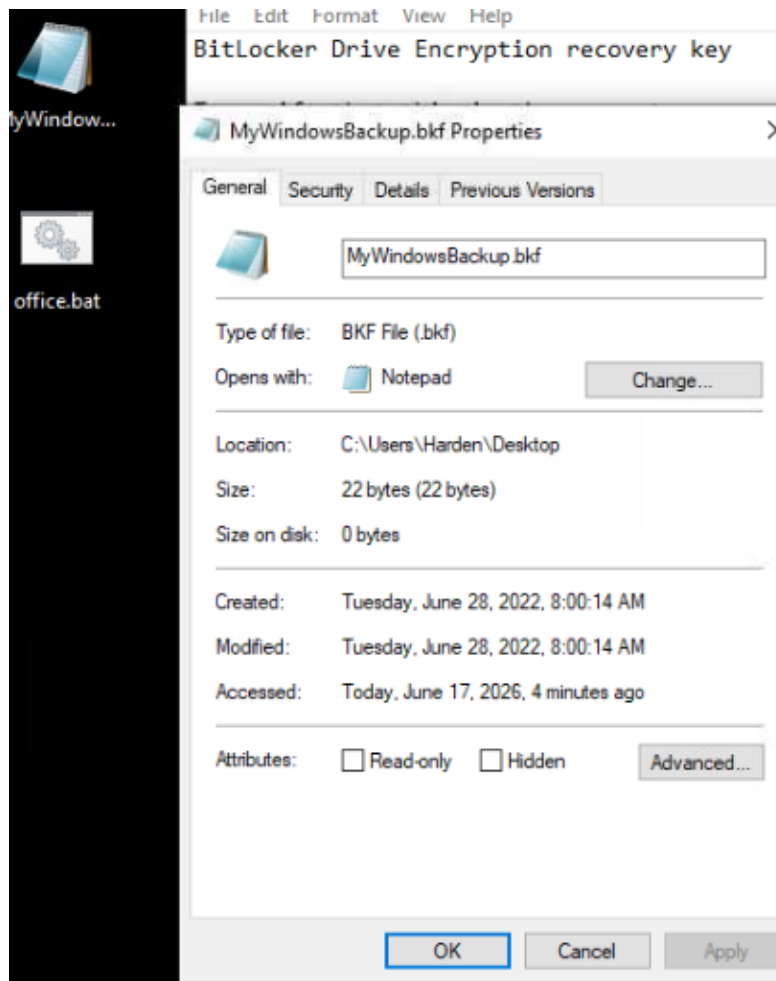
If the above identifier doesn't match the one displayed by your PC, then this isn't the right key to unlock your drive. Try another recovery key, or refer to <https://go.microsoft.com/fwlink/?LinkID=260589> for additional assistance.

How many characters does the BitLocker recovery key have in the attached VM?

48

A backup file is placed on the Desktop of the attached VM. What is the extension of that file?

bkf

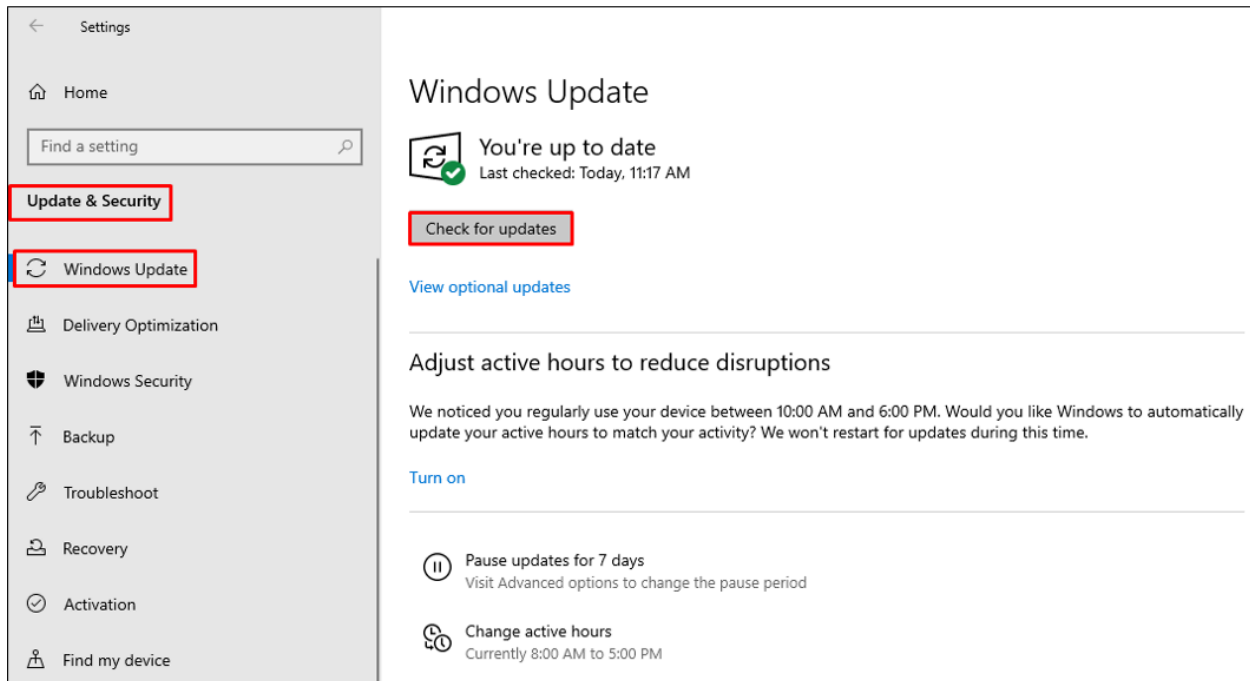


Task 7 - Updating Windows

Hackers are continuously bypassing and exploiting Windows' legitimate features. You can see a list of Windows vulnerabilities. The most critical part of hardening computers is enabling the Windows auto-updates.

Click Start > Settings > Update & Security > Window Updates.

This ensures that all the urgent security updates, if any, are installed immediately without causing any delay. It is most important because the quicker you apply the new Windows protection patch, the faster you can fix the potential vulnerabilities – to ensure the security from the latest known threats.



Remember, users who run the older Windows versions are always at greater risk and vulnerable to new security threats. So, be very careful about this.

Answer the questions below

What is the CVE score for the vulnerability CVE ID CVE-2022-32230?

7.8

Documentation Log

CVE-2022-32230 Potential exploit

SMBv3 FileNormalizedNameInformation NULL Pointer Dereference

Microsoft Windows SMBv3 suffers from a null pointer dereference in versions of Windows prior to the April, 2022 patch set. By sending a malformed FileNormalizedNameInformation SMBv3 request over a named pipe, an attacker can cause a Blue Screen of Death (BSOD) crash of the Windows kernel. For most systems, this attack requires authentication, except in the special case of Windows Domain Controllers, where unauthenticated users can always open named pipes as long as they can establish an SMB session. Typically, after the BSOD, the victim SMBv3 server will reboot.

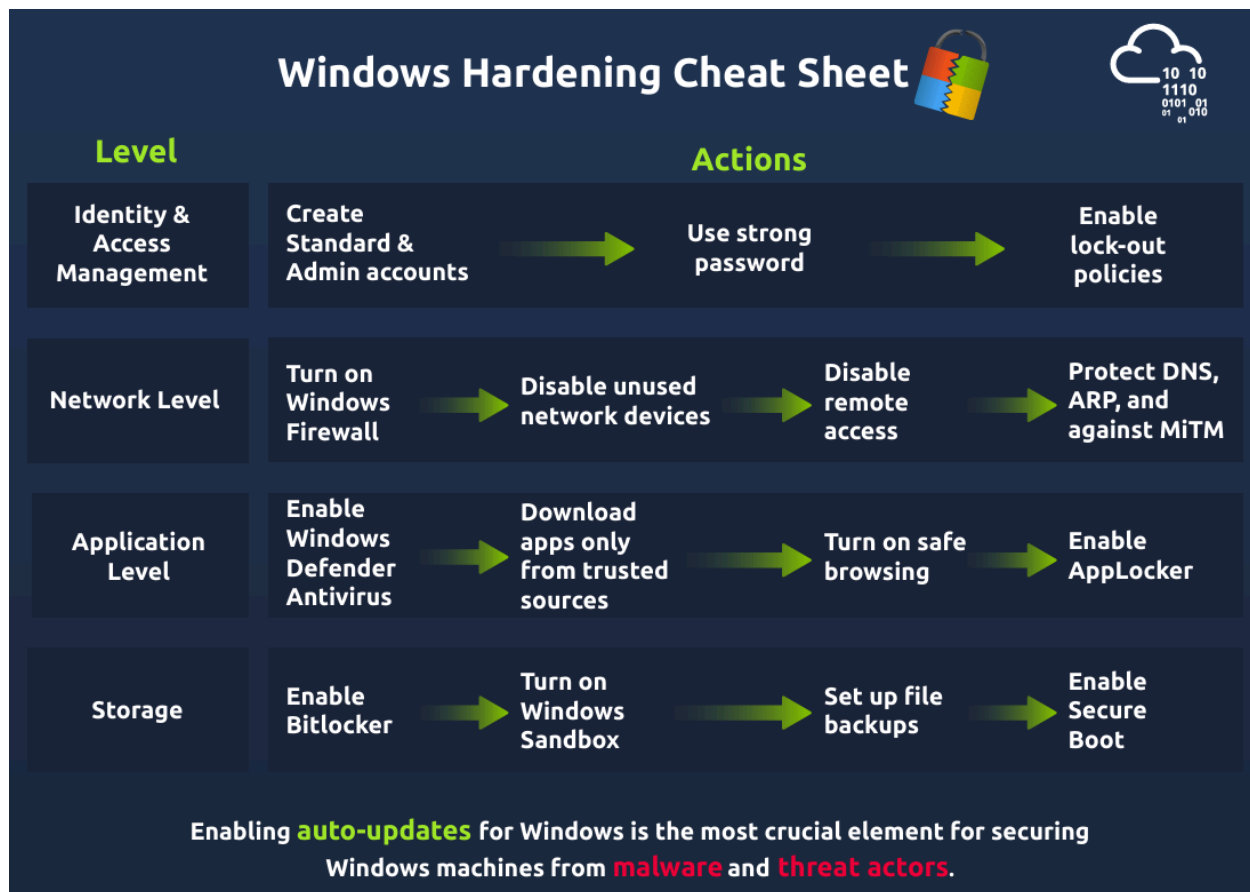
Published 2022-06-14 22:15:10 Updated 2022-06-23 19:28:35 Source [Rapid7, Inc.](#)

View at [NVD](#), [CVE.org](#), [EUVDB](#)

Vulnerability category: **Memory Corruption**

Alternative IDs: EUVD-2022-53430

Task 8 - Cheatsheet for Hardening Windows



Level 1 - Identity & Access Management:

Actions: Create Standard & Admin accounts > Use strong passwords > Enable lock-out policies

Level 2 - Network Level:

Actions: Turn on Windows Firewall > Disable unused network devices > Disable remote access > Protect DNS, ARP, and against MiTM

Level 3 - Application Level:

Actions: Enable Windows Defender Antivirus > Download apps only from trusted sources > Turn on safe browsing > Enable AppLocker

Level 4 - Storage:

Actions: Enable Bitlocker > Turn on Windows Sandbox > Set up file backups > Enable Secure Boot